“中国电子杯”第三界高校 ICT 产教融合创新大赛
初赛作品报告

作品题目：AegisAI

赛题编号：赛题九

摘要

漏洞公告面向的上游项目、发行包和维护分支往往不同，安全人员需要结合部署版本与来源关系判断其对具体资产的影响。本文设计并实现智能体驱动的 AI 安全知识情报系统 AegisAI，连接多源监测、情报富化与资产上下文问答。系统采用受约束的多智能体调查机制：模型生成候选任务计划，服务端独立检查必需任务、权限与依赖；通过 Evidence、Claim 和 Verification 组织原始依据、待核验事实及支持关系，并在包生态与维护分支范围内进行版本比较。调查结果经风险分析与 Integration Gate 验收后，以保留引用、争议和处置依据的结构化形式交付。本文介绍系统架构、核心算法和源码实现，结合限定场景的运行案例讨论任务完整性、来源独立性和版本适用性处理，并说明当前研究与演示版本的验证范围。本系统资产判断完全依赖用户登记的版本快照，不执行主动资产扫描。

关键词：AI 安全情报；多智能体编排；证据核验；资产上下文；结构化问答

目 录

摘要.....I

作品核心机制预览.....VI

第一章 项目背景与需求分析.....1

1.1 项目背景与行业痛点.....1

1.2 核心用户需求与验收方式.....1

1.3 非功能需求与安全受控边界.....2

1.4 赛题评分要求与报告证据映射.....3

1.5 核心技术路线与章节安排.....4

第二章 系统总体设计.....5

2.1 总体设计目标.....5

2.2 “五横两纵”系统总体架构.....5

2.3 核心业务模块与领域数据对象.....6

2.4 部署形态与工程运行机制.....7

2.5 全链路数据流转设计.....8

第三章 智能体架构设计.....9

3.1 受约束自主调查设计思路.....9

3.2 多智能体协同架构与交互闭环.....9

3.3 Planner 目标理解与服务端必需任务不变量.....9

3.4 Investigation Agent 的受控调查与信息获取.....10

3.5 Verification Agent 的声明核验与血缘消歧.....10

3.6 Security Analysis Agent 的资产上下文风险判定.....10

3.7 Integration Gate 的六维统一验收机制.....11

3.8 角色协作契约与类型化产物交接.....12

第四章 情报监测模块设计.....14

4.1 监测模块设计目标.....14
4.2 七大类多源异构情报覆盖体系.....14
4.3 增量采集、快照封存与标准化流程.....15
4.4 自动化调度机制与监测时效保障.....16
4.5 监测数据交付契约与读取接口.....16
第五章 情报富化模块设计.....17
5.1 富化模块设计目标.....17
5.2 六维富化任务编排与事务执行边界.....17
5.3 多维深度富化机制设计.....17
5.3.1 CVSS 严重性校验与 CWE 弱点映射.....17
5.3.2 多维护分支影响版本与修复版本解析.....18
5.3.3 授权资产关联与固定快照封存.....18
5.3.4 PoC 验证状态与补丁（Patch）状态分级语义.....18
5.3.5 学术论文、技术博客关联与 Evidence 绑定.....19
5.4 富化执行流水线与跨源血缘消歧实证.....19
5.5 富化领域输出与下游消费契约.....20
第六章 情报问答模块设计.....22
6.1 问答模块设计目标.....22
6.2 输入上下文预检与混合语义检索设计.....22
6.3 自然语言调查工作流与状态机设计.....22
6.4 AnswerEnvelope 结构化封存输出设计.....23
6.5 任务支持范围与安全交互边界.....23
6.6 跨文档多跳关联推理机制.....23
第七章 关键技术实现.....24
7.1 工程技术栈选型与依据.....24

7.2 Model Gateway 统一模型调用网关.....25
7.3 自研 DAG Runtime 与 Tool Gateway 权限管控.....26
7.4 核心源码深度解析.....27
7.4.1 服务端必需任务补齐与三层计划复验.....28
7.4.2 跨源血缘归组与声明支持度裁定.....29
7.4.3 资产适用性前置核验与答案证据发布过滤.....30
7.5 类型化调查 REST API 与前后端契约.....30
7.6 幂等控制、访问隔离与异常容错处理.....31
7.7 Integration Gate 裁定实现与答案发布原则.....32
第八章 传统安全分析与本项目机制对比.....33
8.1 对照维度与分析基准说明.....33
8.2 全流程核心机制对比分析.....33
第九章 系统实现与功能展示.....35
9.1 实机运行环境与展示口径.....35
9.2 多源情报监测与协同调查工作台效果展示.....35
9.3 情报深度富化与跨源证据连接效果.....37
9.4 典型案例一（C08）：维护分支精准匹配与策略验收分析.....38
9.5 典型案例二（C09）：公告范围差异识别与计划自愈恢复.....39
9.6 历史端到端调查记录.....40
第十章 测试验证与性能分析.....42
10.1 测试验证体系与评价目标.....42
10.2 工程契约与自动化回归测试.....42
10.3 三大核心业务模块功能验证.....42
10.4 AegisBench 评测基准与实验环境配置.....43
10.5 团队最新自测汇总与结果说明.....43

10.6 配对实验中的局部机制对照.....44
10.7 综合测试结果与端到端响应耗时分析.....44
第十一章 创新点总结.....46
11.1 面向 AI 安全场景的受约束多 Agent 自主调查架构.....46
11.2 跨源同出处消歧的 Evidence 可信安全分析机制.....46
11.3 包生态与维护分支约束的资产风险判定闭环.....46
11.4 核心创新机制与赛题评分要求映射.....46
第十二章 应用价值与未来展望.....48
12.1 典型行业落地应用场景.....48
12.2 未来演进与技术扩展工作.....48
参考文献.....49
附录 A 工程证据索引与可复现清单.....50

作品核心机制预览

AegisAI 面向 AI 软件组件的漏洞调查，将多源监测、情报富化与资产上下文问答连接起来。系统重点解决三个问题：调查步骤是否完整、多个来源是否真正独立、公告范围是否适用于目标组件。

任务完整性：Planner 负责选择调查路径，服务端根据原始请求保留必需任务，并在执行前检查输入、权限与依赖。

证据可信度：把原文、声明及支持关系分别存储，识别共同出处，保留冲突与证据缺口。

资产适用性：结合包生态、包名和维护分支比较登记版本，修复建议绑定相应的已核验声明。

交付可追溯：通过类型化产物交接与统一门禁检查，保留调查轨迹、引用和处置依据。

注：资产比对依赖用户登记版本快照，无自动资产扫描能力；评测数据集来源于开发阶段接触的公告簇，非完全独立留出测试集。

第一章 项目背景与需求分析

1.1 项目背景与行业痛点

随着大语言模型、推理服务框架及智能体应用在关键业务场景中的规模化部署，AI 软件供应链与基础设施漏洞呈现高频高危态势。在企业安全运营与应急响应中，分析人员面临的核心问题是：某个已登记的 AI 软件组件（如 vLLM、LangChain、PyTorch 等）是否受到最新公开漏洞公告的实际影响，应当选用哪一维护分支的修复版本，以及还需核实哪些运行时部署前提。通用漏洞数据库提供标准化漏洞标识与基础严重性评分[1][2]，开源社区与维护方安全公告描述具体的触发条件与受影响分支，而企业资产库存则记录实际部署的发行包版本。由于不同渠道在组件命名、版本区间语法及更新时效上存在显著差异，传统依赖人工检索与经验比对的方式面临严重的信息过载与研判滞后问题。赛题九提出构建自动化、智能体驱动的 AI 安全知识情报系统，涵盖情报监测、情报富化与情报问答三大核心模块，正是对这一真实安全运营痛点的系统化工程响应[3]。

在 AI 安全情报自动化研判中，最关键的技术难点在于跨源实体与事实依据的精准连接：第一，上游源码项目与下游包管理器发行包（如 PyPI）往往采用不完全一致的命名与版本空间，且同一项目常并行维护多个长期支持分支（如 0.3.x 与 1.x）；第二，GitHub、OSV、NVD 及技术博客中的多个 URL 往往转载自同一份上游维护方公告，若简单按链接数量统计支持度，极易将“同源多次转载”误判为“多源独立交叉印证”；第三，漏洞通用严重性（CVSS）、上游修复版本发布（FIXED_VERSION）、公开概念验证代码（PoC）与本地资产风险等级分别对应不同维度的安全事实。为此，AegisAI 在多源自动化采集与语义检索的基础上，重点构建了服务端必需任务约束、跨源共同出处（Lineage）消歧核验与多维护分支资产版本比对机制，将碎片化的外部情报转化为可追溯、可复核的资产级风险判断。

1.2 核心用户需求与验收方式

本系统面向安全运营中心（SOC）工程师、漏洞应急响应团队及 AI 软件供应链资产管理人员。用户输入自然语言安全查询、漏洞标识或目标登记组件后，系统能够自动完成多源情报汇聚、声明级证据核验、精确版本区间匹配，并输出附带原文引用与处置依据的结构化报告。对于缺失关键版本参数的查询，系

统主动识别并返回所需补充的上下文条件；对于多源描述存在分歧的漏洞，系统完整保留各方适用范围与待复核争议项。表 1 给出了核心业务需求与系统可验证交付物之间的映射关系。

表 1 核心用户需求、系统交付结果与工程验收方式

需求编号	典型安全运营问题	系统结构化交付结果	工程核验与验收方式
R01	最近发现了哪些最新 AI 安全漏洞与研究动态？	多源采集记录、来源发布时间、系统入库时间、原文快照及增量同步批次状态	采集回执（SourceObservation）与 RawDocument SHA-256 原文对照
R02	目标漏洞具备哪些权威技术资料与可信证据？	官方公告、结构化声明（Claim）、支持/反证材料（Evidence）、共同血缘归组与争议项	原文 JSON/XML 定位指针、SHA-256 哈希链与血缘键（lineage_key）核验
R03	本地登记的 AI 组件版本是否受到该漏洞影响？	精确包生态与包名匹配、调查时刻固定的组件版本观察、多维护分支区间判定结果	调查封存的资产版本快照（VersionObservation）与分支区间边界测试
R04	是否存在公开可用的 PoC 验证代码或修复补丁？	公开候选仓库/补丁链接、与目标漏洞的显式关联证据、验证状态分级标识	严格区分候选发现、静态关联确认（PoC_LINKED）与实际利用验证
R05	系统依据什么证据链得出该资产风险与优先级结论？	已核验事实集合、本地风险评估规则、原文引用列表及六维门禁审查结论	三角色类型化产物（Artifact）、工具回执与 Integration Gate Trace 审计
R06	针对受影响组件应采取什么具体修复动作？	精确到目标维护分支的升级版本建议、关联证据引用及需人工复核的部署前提	修复声明（FIXED_VERSION）证据绑定检查与 AnswerComposer 发布过滤核验

1.3 非功能需求与安全受控边界

面向企业级安全分析场景，系统在非功能层面重点保障全链路可追溯性、受控执行安全性与历史结果可复查性：第一，所有采纳的安全事实均强制关联 RawDocument 原文快照与声明级核验产物，杜绝无出处断言；第二，智能体任

务执行受服务端工具白名单、读写/外网权限分级与重试预算（最多 2 次规划尝试、单次调用超时控制）严格约束；第三，调查记录与拥有者身份（Owner）及幂等键（Idempotency-Key）强绑定，封存后的 AnswerEnvelope 完整保留调查时刻的资产快照与证据状态，确保任意历史调查均可按原上下文精确复盘。系统基于授权登记资产库存与受控公开情报源运行，所有评估过程均为安全只读分析，不执行未经授权的外部主动探测或破坏性载荷验证。

1.4 赛题评分要求与报告证据映射

本报告严格对照《“中国电子杯”第三届高校 ICT 产教融合创新大赛赛题九》的功能指标、性能指标、优化指标及文档质量要求组织编写。表 2 给出了初赛九项评分标准在本报告中的设计章节位置、核心实现机制与实证材料映射。

表 2 初赛九项评分标准（100 分）与报告章节及工程实证映射

评分大项	报告章节位置	核心设计与工程实现依据
功能指标（45 分）	第 4 章、9.2 节	构建覆盖 CVE、NVD、OSV、GitHub Advisory、KEV/EPSS、安全博客 RSS、arXiv 论文及标准规范的 7 大类数据源适配体系，支持 Checkpoint 增量同步与原文 SHA-256 快照封存
功能指标（45 分）	第 5 章、9.3—9.5 节	实现 vendor、epss、kev、poc、patch、version 六维依赖编排富化，涵盖 CVSS/CWE 校验、多维护分支解析、PoC/Patch 关联分级、384 维本地向量文献关联与领域事务回滚机制
功能指标（45 分）	第 6 章、9.4—9.6 节	支持自然语言意图解析、跨文档多跳关联推理（别名→生态→分支→资产→证据）、缺上下文快速识别（NEED_CONTEXT）及 AnswerEnvelope 结构化可溯源答案交付
性能指标（15 分）	4.4 节、10.5 节	记录来源发布时间与首次入库时间，提供可配置轮询、增量游标和批次状态；时效评价口径见第十章
性能指标（15 分）	5.3—5.4 节、10.3—10.7 节	结构化字段经 Normalizer 转换，通过声明核验与共同出处归组控制证据采纳；评测结果见第十章

评分大项	报告章节位置	核心设计与工程实现依据
性能指标（15 分）	6.6 节、9.4—9.6 节、10.4—10.6 节	基于 49 题审批级基准 AegisBench-v0.4 开展全链路自动化评测与真人配对裁定，通过 C08、C09 与 vLLM 0.6.5 实机运行完整展示多跳推理链与证据引用
优化指标（25 分）	第 3 章、7.2—7.4 节	采用服务端必需任务约束与候选 DAG 规划，四角色协作，并由 Runtime、Tool Gateway 和 Integration Gate 控制执行与交付
优化指标（25 分）	2.5 节、4.3 节、5.2 节、9.5 节	打通多源增量监测、标准化、六维富化、向量索引到多 Agent 调查问答全流程自动化；具备 Planner 字段级错误反馈自愈（≤2 次）、PARTIAL 批次隔离与异常留存能力
文档质量（15 分）	全报告第 1—12 章、附录 A	提供架构与流程图、核心源码说明、真实运行案例和工程证据索引，按第 1—12 章及附录 A 查阅

1.5 核心技术路线与章节安排

本报告以“外部公告如何转化为具体资产的影响判断”为主线。总体架构与角色分工见第二、三章；三大业务模块见第四至六章；第七章集中说明核心代码、依赖约束和接口契约；第九、十章呈现实际运行与测试结果；最后总结技术特点与应用边界。

第二章 系统总体设计

2.1 总体设计目标

AegisAI 的总体设计目标是让每一次针对 AI 软件组件的安全调查都具备完整、可检验的工程依据：外部公告精确指向什么包生态与维护分支、本地登记的部署版本是否落入受影响区间、风险与优先级结论建立在哪些经核验的证据之上、以及是否存在同源转载或范围分歧等需要注意的条件。为此，系统将多源情报采集、结构化富化、多角色智能体推理和最终门禁验收建立在统一的可追溯领域对象之上，消除安全分析人员在漏洞库、厂商公告、代码仓库与本地资产台账之间的手工拼接成本。

2.2 “五横两纵”系统总体架构

系统采用职责清晰、层次解耦的“五横两纵”总体技术架构，自底向上依次划分为多源异构 AI 安全情报源层、情报监测与标准化层、多模安全知识处理底座层、智能体协同编排与门禁层、以及交互展示与问答服务层；两侧纵向贯通“全链路证据溯源与审计闭环”和“受控执行与安全护栏”两大保障体系，总体架构如图 1 所示。

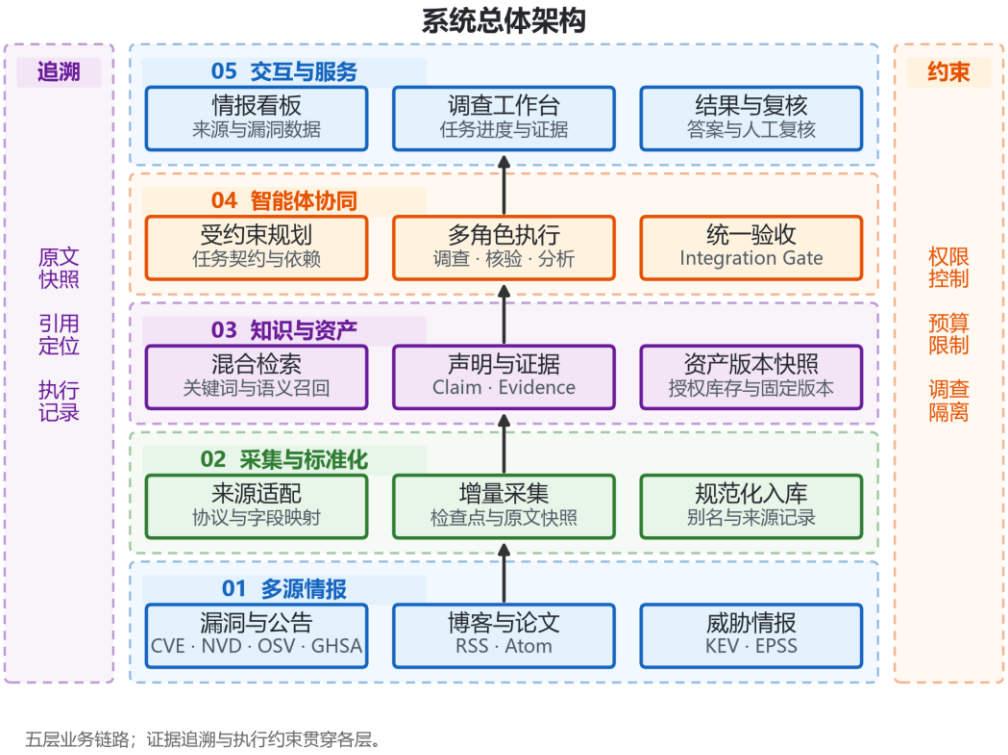


图 1 AegisAI 智能体驱动的 AI 安全知识情报系统“五横两纵”总体技术架构

在运行机制上，正式调查 HTTP 请求由 Orchestrator 统一编排调度各智能体角色与受控工具。其中，get_asset 和 inspect_component_version 从授权资产库存中读取目标组件信息并生成固定快照；PostgreSQL 关系数据库持久化保存原始来源快照、执行轨迹、角色产物与封存答案。安全博客、学术论文和公开候选仓库首先进入多模知识底座，必须经过 Claim 与 Evidence 核验机制筛选后，方可在风险评估与答案合成中作为正式事实依据。RawDocument 保存原始响应字节或脱敏字段快照，并通过 SHA-256 哈希保障内容完整性；来源权威性与支持关系则由出处身份、血缘键（lineage_key）及核验规则共同判定。

2.3 核心业务模块与领域数据对象

围绕赛题三大核心能力，情报监测模块负责多源适配器配置、增量游标采集、原文快照封存与结构化转换；情报富化模块围绕漏洞记录扩展厂商公告、CVSS/CWE 评分、KEV/EPSS 威胁情报、PoC/Patch 候选、多分支版本范围及关联论文/博客；情报问答模块负责解析复杂安全查询、编排执行调查 DAG、核验跨源证据并结合资产快照生成结构化答案。授权资产库存与混合检索引擎（关键词 + 384 维本地向量）为三大模块提供统一支撑。表 3 列出了贯穿系统全链路的核心领域数据对象及其工程约束。

表 3 AegisAI 核心领域数据对象及关键工程约束

领域数据对象	所属模块层次	核心业务作用	关键完整性与安全约束
RawDocument / SourceObservation	情报监测与标准化层	保存原始响应字节快照及单次来源采集元数据	强制绑定 source_id、捕获时间戳、SHA-256 内容哈希与原文 JSON/XML 定位指针
NormalizedVulnerability 标准化漏洞对象	情报监测与知识层	聚合跨源漏洞主标识、别名簇（CVE/GHSA）与产品信息	统一投影核心属性，同时完整保留各来源独立的 SourceObservation 采集记录
Claim / Evidence 声明与证据对象	情报富化与核验层	分别表达待核验安全事实命题与具体支持/反证材料	强制同漏洞、同作用域（scope_key）对齐，显式标注 stance（支持/反证）与血缘键

领域数据对象	所属模块层次	核心业务作用	关键完整性与安全约束
VersionObservation 资产版本观察快照	资产库存与调查层	封存单次调查时刻读取到的授权登记资产组件版本	仅可由 get_asset / inspect_component_version 工具回执生成，严禁模型猜测缺失版本
ImpactVersionEvidence 版本影响范围证据	情报富化与分析层	保存多维护分支受影响区间（introduced/fixed/last_affected）	证据级核验状态独立计算，不得借用其他证据或非同分支记录的确认状态
AgentRun / Task / Artifact / ToolReceipt	智能体运行时层	记录 DAG 任务调度状态、角色结构化产物与工具调用回执	全部绑定唯一 investigation_id 与 owner_id，确保跨调查访问隔离与全链路审计
IntegrationResult / Gate Trace	统一验收门禁层	保存六维门禁规则检查明细、目标覆盖度与汇总状态	基于不可变 IntegrationContext 确定性执行，阻断未通过核验或跨调查借用的产物
AnswerEnvelope 结构化封存答案	问答交付服务层	向用户与前端工作台交付可追溯、可复核的最终调查结论	严格分离 verified_claims、citations、disputed_claims、recommended_actions 与 warnings

2.4 部署形态与工程运行机制

后端采用 FastAPI、SQLAlchemy、Alembic 与 PostgreSQL 提供类型化接口、模式迁移与持久化。前端采用原生 JavaScript ES modules 与 History Router，Node 服务提供静态页面和同源 API 代理；总览、漏洞、资产、复核、调查和系统页面共用导航、全局搜索与状态组件。Model Gateway 独立管理本地生成模型和向量模型，DAG Runtime 与 Tool Gateway 执行计划及权限约束。

2.5 全链路数据流转设计

图 2 展示了外部多源数据如何经过标准化、富化与核验进入多智能体调查链路。原始外部情报首先被封存为带 SHA-256 哈希的 RawDocument 快照，随后分流至漏洞结构化富化流水线与非结构化文档（博客/论文）向量索引流水线，共同沉淀至 Claim、Evidence 与血缘知识底座。当收到自然语言调查请求时，检索模块召回候选线索，Verification Agent 判定证据能否有效支持目标声明，VersionObservation 固定本次比对的本地资产组件版本，Security Analysis Agent 与 Integration Gate 最终协同生成可追溯的 AnswerEnvelope。

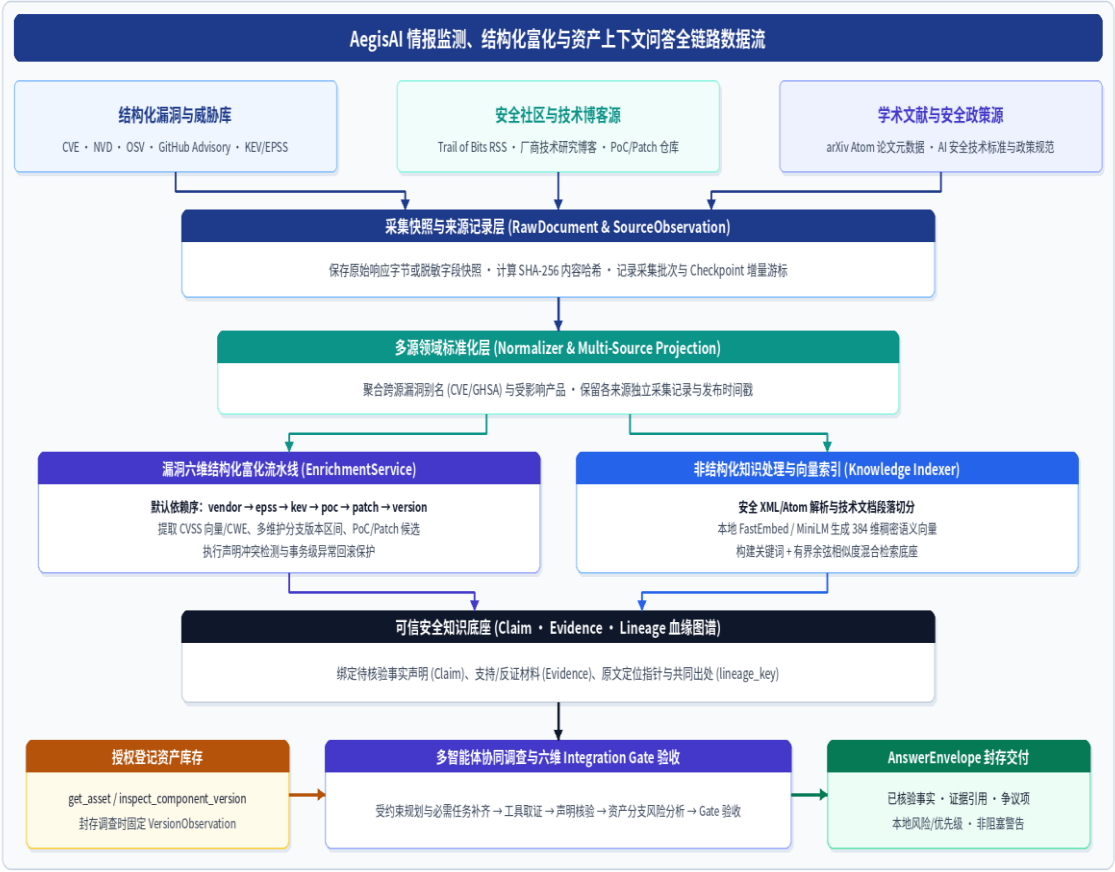


图 2 AegisAI 多源情报采集、结构化富化与资产上下文问答全链路数据流

第三章 智能体架构设计

3.1 受约束自主调查设计思路

安全调查既需要根据问题灵活组合工具，也需要一致地核对证据、版本范围与资产身份。AegisAI 将规划、取证、核验和风险分析划分为四个角色，以类型化产物交接；Integration Gate 在交付前统一检查任务与证据链。

3.2 多智能体协同架构与交互闭环

图 3 展示规划与执行两部分的协作关系。Planner 输出候选计划，服务端负责任务完整性及合法性检查；通过校验后，调查、核验与分析角色依次消费上游产物，最终交由 Gate 验收和答案合成。



图 3 AegisAI 多智能体协同架构：服务端必需任务不变量补齐与多角色交接闭环

3.3 Planner 目标理解与服务端必需任务不变量

Planner 负责理解目标并组合工具，必需业务步骤则由服务端从原始请求中确定。这样，模型可以选择精简的调查路径，同时资产影响类问题仍需保留资产读取与版本检测。缺少上下文的请求先进入补充信息流程。

候选计划被拒绝时，Planner 接收字段路径、错误原因和原计划上下文，在既定预算内修正；是否执行由同一套服务端校验器决定。

3.4 Investigation Agent 的受控调查与信息获取

Investigation Agent 严格按照已签发的 ValidatedPlan 调用服务端注册的 8 大安全工具获取情报与资产数据，具体包括：get_vulnerability（按标识读取标准化漏洞详情）、search_vulnerabilities（多条件检索漏洞列表）、inspect_component_version（检测目标组件版本快照）、get_evidence（拉取声明级支持与反证材料）、get_claims（读取待核验安全声明）、relation_query（查询跨实体关联关系）、semantic_search（384 维本地向量语义检索）以及 get_asset（读取授权登记资产清单）。每次工具调用均由 Tool Gateway 生成包含输入摘要、输出哈希、耗时与状态的 ToolReceipt，并汇总封装为 InvestigationArtifact。资产版本严格以授权库存回执为准，漏洞范围严格以来源采集记录为准；若特定渠道资料缺失，调查角色如实记录缺口并交由下游核验与门禁模块处理。

3.5 Verification Agent 的声明核验与血缘消歧

Verification Agent 读取本次调查的声明及关联证据，检查漏洞身份、作用域、原文定位与有效性，输出各声明的核验状态、采纳依据和争议项。下游风险分析使用该核验产物，而不是仅凭检索结果形成结论。

3.6 Security Analysis Agent 的资产上下文风险判定

风险等级判定全部依赖**用户登记 VersionObservation 资产快照**；系统不会自动探测真实业务资产。如果录入版本错误，风险输出结果会同步出错。Security Analysis Agent 将经过核验的漏洞事实（CVSS 严重性、KEV 在野利用标志、PoC 关联状态、多分支受影响范围）与调查时刻封存的授权资产快照（VersionObservation）相结合，执行两阶段确定性判定：第一阶段调用 match_asset 与 match_version，在精确核对包生态（如 PyPI）与包名的前提下，将固定资产版本与已确认（CONFIRMED）的各维护分支版本区间逐一比对；第二阶段在确认资产受影响（AFFECTED）且前置核验通过的条件下，调用 assess_risk 与 assess_priority（基于 asset-priority-v1 策略）计算本地资产风险等级与处置优先级：

严重风险（CRITICAL / P1）：组件版本确认受影响，且同时满足 KEV 在野利用已确认与资产具备外部网络暴露面（internet_exposed）。

高危风险（HIGH / P1–P2）：组件版本确认受影响，且命中 KEV 目录、或已核验 CVSS 严重性达到 HIGH/CRITICAL（分值 ≥ 7.0）、或存在经核验的公开 PoC 关联证据。

中低风险与受控回退（MEDIUM / LOW / UNKNOWN）：确认受影响且具备中低严重性依据时判定为 MEDIUM；当前置版本核验处于冲突（CONFLICT）或证据不足时，严格保持风险为 UNKNOWN、优先级为 REVIEW_REQUIRED，阻断无依据的乐观安全结论。

3.7 Integration Gate 的六维统一验收机制

在向用户交付最终答案前，Integration Gate 对固定不可变的 IntegrationContext 执行 Completion、Integrity、Evidence、Consistency、Objective 与 Freshness 六大类确定性规则审查，并按 FAILED>HUMAN_REVIEW_REQUIRED>REPLAN_REQUIRED>PASS_WITH_WARNINGS>PASS 的严格优先级汇总裁定结果。表 4 列出了六类门禁检查的核心审计问题与阻断触发条件。

表 4 Integration Gate 六维统一验收检查规则与阻断机制

门禁检查类别	核心审计问题	核验对象与契约条件	典型阻断或降级触发示例
Completion（任务完备性）	所有必需任务与角色产物是否完整就绪？	检查 ValidatedPlan 中的必需节点及 Investigation / Verification / Analysis 三类 Artifact 状态	必需资产读取任务失败、被取消或因上游依赖异常处于 BLOCKED 状态
Integrity（链路完整性）	调查身份、引用链与哈希快照是否闭合？	核对所有 Artifact、ToolReceipt、Claim 与 Evidence 的 investigation_id、raw_document_id 及 SHA-256 哈希	核验产物引用了不属于当前调查实例的旧 Artifact 或原文哈希缺失
Evidence（证据充分性）	支撑关键决策的事实是否具备直接有效证据？	校验采纳为已确认（CONFIRMED）的声明是否具备当前有效、同作用域的合格支持材料	引用链接存在但立场为反证/无关，或将候选发现直接当作已确认利用事实

门禁检查类别	核心审计问题	核验对象与契约条件	典型阻断或降级触发示例
Consistency（跨角色一致性）	核验角色、风险分析角色与答案摘要是否自洽？	比对 Verification 状态、Analysis 版本匹配结论与最终推荐处置动作的逻辑一致性	前置版本核验为 UNKNOWN 或 CONFLICT，但下游风险结论却输出无条件安全或确认受影响
Objective（目标覆盖性）	输出结果是否完整回答了原始查询的必要目标项？	基于已编码的 Objective 契约检查范围评估、资产匹配、风险评级与修复建议的覆盖率	用户询问特定登记资产的风险与优先级，系统仅返回通用漏洞简介而遗漏资产判定
Freshness（时效与快照）	来源发布时间、采集记录与资产快照时间是否完备？	检查 SourceObservation 的 published_at / observed_at 及 VersionObservation 的快照时间戳	仅有本地抓取时间而缺失上游公告发布时间，触发非阻塞时效警告（PASS_WITH_WARNINGS）

3.8 角色协作契约与类型化产物交接

各智能体角色之间禁止共享非结构化自由文本上下文，所有阶段交接均通过严格定义 Schema 的 Artifact、ToolReceipt 与唯一调查标识完成。表 5 总结了多角色协作链路的职责分工、交接产物及与赛题架构要求的对应关系。

表 5 AegisAI 多智能体角色职责、类型化交接产物与赛题要求映射

智能体角色 / 核心组件	核心业务职责	类型化输出与交接产物	赛题架构与能力对应
Planner & task_invariants	解析安全查询意图、提取服务端必需任务不变量、生成并补齐受约束调查 DAG	候选计划 JSON、RequiredTask 集合、schema_feedback 重试记录、ValidatedPlan	Agent 自主决策、受控任务编排与执行边界保障
Investigation Agent	按拓扑依赖调用 8 大受控安全工具，拉取漏洞、声明、证据、文献与授权资产快照	ToolReceipt 列表、VersionObservation 固定版本快照、InvestigationArtifact	多工具协同调用、多源异构信息汇聚
Verification Agent	执行跨源同出处血缘归并（origin）与声明级支持/反证核验（evaluate_claim）	VerificationArtifact（含各声明核验状态、独立血缘组、冲突详情与排除原因）	多角色协作、可信安全分析与抗幻觉核验

智能体角色 / 核心组件	核心业务职责	类型化输出与交接产物	赛题架构与能力对应
Security Analysis Agent	核对包生态与包身份，执行多维护分支版本区间匹配，计算本地资产风险与优先级	AnalysisArtifact（含分支比较矩阵、本地风险等级、asset-priority-v1 优先级与建议）	情报富化影响评估、资产上下文精准风险判断
Integration Gate	在不可变上下文上执行六维确定性门禁检查，裁定发布、警告、复核、重规划或失败	IntegrationResult、六维规则审查明细、Objective 覆盖度报告与 Gate Trace	架构严谨性、全链路异常处理与质量门禁
AnswerComposer & AnswerEnvelope	执行 eligible() 证据发布过滤，组装并持久化不可变的结构化答案包	AnswerEnvelope（分离 verified_claims、citations、disputed_claims、actions 与 warnings）	深度问答完整性、推理链可解释与可审计交付

第四章 情报监测模块设计

4.1 监测模块设计目标

情报监测模块作为系统的感知底座，负责对主流漏洞数据库、厂商安全公告、威胁利用目录、安全社区博客、学术研究论文以及技术标准与政策规范进行自动化监测、增量拉取与标准化入库。模块设计以“多源异构协议统一适配、Checkpoint 断点增量恢复、RawDocument 原文哈希留存、缺省字段诚实置空”为核心原则，确保下游富化与问答模块能够按精确来源身份与时间戳回查每一份原始材料。

4.2 七大类多源异构情报覆盖体系

系统围绕漏洞数据库、代码与安全公告、威胁情报、博客、学术论文及标准规范等渠道设计采集适配层。表 6 列出各类来源的协议方式与标准化输出；来源适配能力与持续采集效果分别在设计和运行章节说明。

表 6 七大类 AI 安全情报数据源适配机制与标准化领域输出

数据源序号与类别	代表性渠道与协议格式	采集适配与解析机制	标准化领域输出对象	数据治理与边界规则
① 官方通用漏洞库（CVE）	MITRE CVE Record（CVE JSON 5.0）	基于 REST 接口按 CVE ID 与更新时间游标拉取，保存原始 JSON 字节流	漏洞主标识、基础描述、分配机构（CNA）与参考链接集合	保留官方原始状态（PUBLISHED / REJECTED），与下游多源别名建立双向索引
② 国家漏洞数据库（NVD）	NIST NVD API 2.0（结构化 JSON）	支持时间窗口与增量游标分页请求，提取 CVSS v3.1/v4.0 向量与 CWE 分类	NVD 来源观察记录、CVSS 向量/分值断言、CWE 弱点映射及 CPE 列表	记录 NVD 评估时间戳；受影响产品为空时保持空值，严禁跨记录借用补全
③ 开源生态漏洞库（OSV）	OSV.dev / PyPI 等生态库（OSV Schema JSON）	按 AI 组件包名与生态（PyPI 等）批量同步，解析 affected[].ranges 语义事件	包生态（ecosystem）、精确包名、introduced / fixed / last_affected 版本事件	严格按生态解析 introduced=0（表示该分支无明确下界），保留跨源 alias 关联

数据源序号与类别	代表性渠道与协议格式	采集适配与解析机制	标准化领域输出对象	数据治理与边界规则
④ 厂商与社区公告（GitHub Advisory）	GHSA / 维护方安全公告（GraphQL / REST JSON）	拉取维护方发布的原始 GHSA 公告正文（Markdown）与结构化受影响分支表	维护方权威公告快照、多维护分支受影响区间、官方修补版本与临时缓解措施	作为 origin() 跨源血缘消歧的核心锚点，识别 OSV/NVD 对同一 GHSA 的转录关系
⑤ 威胁利用与概率情报（KEV & EPSS）	CISA KEV 目录 / FIRST EPSS（JSON / CSV 订阅流）	定时同步已知在野利用漏洞目录（KEV）与 30 天内利用概率评分（EPSS）	KEV 在野利用确认标志、添加日期、处置期限及 EPSS 概率/百分位分值	作为 Security Analysis Agent 判定 CRITICAL/HIGH 风险等级的核心威胁特征输入
⑥ 安全社区技术博客（Security Blogs）	Trail of Bits Blog 等（RSS 2.0 / 安全 XML）	采用防 XXE 注入的安全 XML 解析器提取技术文章标题、正文、作者与发布时间	BlogArticle 知识对象、分段文本块（Chunks）及本地 384 维 MiniLM 语义向量	支持语义与关键词混合检索；文章与特定 CVE 的事实关联须经核验规则确认
⑦ 学术论文与标准规范（arXiv & Standards）	arXiv API（Atom XML）及 AI 安全技术标准/政策文档	按 AI 安全主题词与分类增量拉取 arXiv 论文元数据与摘要，解析标准/政策条款条目	ResearchPaper 知识对象、安全标准/策略规则契约（如 triage 策略）及向量索引	语义相似度仅用于候选文献召回，正式论文—漏洞关联与命名策略执行须经显式契约核验

4.3 增量采集、快照封存与标准化流程

情报监测与标准化入库流程如图 4 所示。系统采集器启动时首先读取数据源配置与上次成功提交的 Checkpoint 游标，发起受控网络拉取。当响应获取并完成基础协议解析后，系统立即将原始字节流或脱敏投影保存为 RawDocument，计算 SHA-256 哈希并生成 SourceObservation；随后由 Normalizer 将异构字段映射为标准化领域对象，在数据库事务内完成幂等去重入库，并在事务成功提交后推进 Checkpoint 游标。若批次内部分条目遇到网络抖动或上游格式异常，系统将该批次标记为 PARTIAL 或 FAILED，完整保留已成功入库条目与失败条目的错误诊断栈，同时冻结原游标以便下一调度周期从断点精准续采。

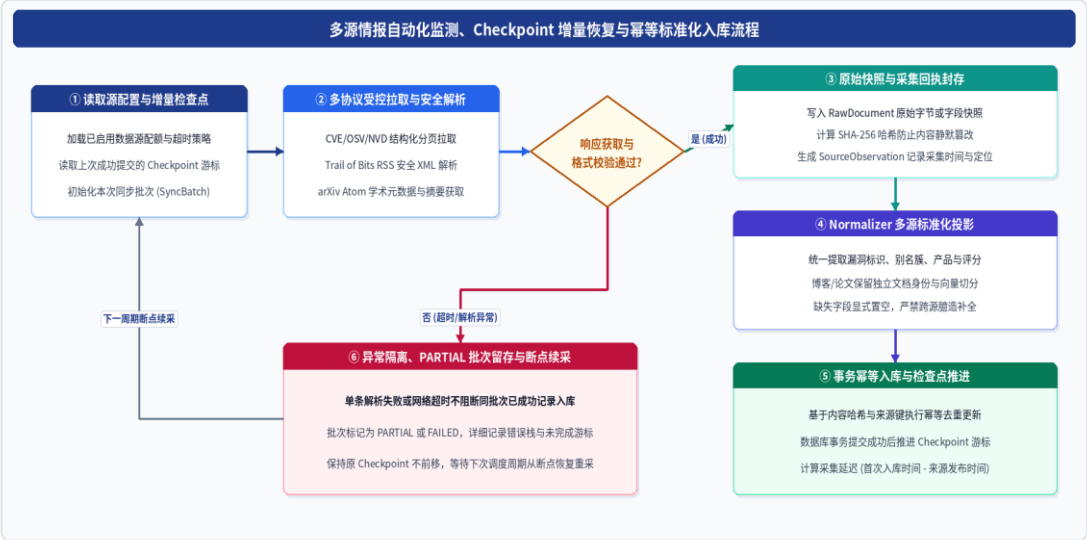


图 4 AegisAI 多源情报增量监测、Checkpoint 断点续采与幂等标准化入库流程

4.4 自动化调度机制与监测时效保障

系统内置自动化同步与增量调度入口，支持按数据源类别独立配置轮询周期、单批次拉取上限（Bounded Fetch）与超时重试策略。在监测时效性度量上，系统严格定义单条情报的采集延迟为：

$$\Delta t_{collect}(d) = t_{first_ingested}(d) - t_{published_source}(d)$$

适用条件：来源发布时间存在且有效；缺失时单独记录。

说明：轮询周期用于调度配置，端到端时效按实际发布时间与首次入库时间统计。

4.5 监测数据交付契约与读取接口

监测结果通过 GET /api/v1/sources、GET /api/v1/sync-runs 和 GET /api/v1/vulnerabilities 及详情接口读取。下游连接字段包括 source_id、raw_document_id、漏洞标识与来源记录标识；published_at、observed_at 和批次状态用于区分来源发布时间、采集时间及处理进度。接口字段与原文快照共同支撑后续富化和溯源。

第五章 情报富化模块设计

5.1 富化模块设计目标

原始漏洞记录通常只包含简要概述，难以直接回答组件分支适用性与修复方案。情报富化模块旨在围绕基础漏洞记录开展六维深度扩展与结构化加工：补充并校验 CVSS 严重性评分与 CWE 弱点分类、提取多维护分支受影响版本与修复版本区间、关联授权登记软件资产快照、搜集并分级评估公开 PoC 验证代码与补丁（Patch）状态、关联 AI 安全学术论文与技术分析文章，并将所有富化产出统一建模为带作用域与血缘标识的 Claim 与 Evidence，为深度问答提供高置信度的知识输入。

5.2 六维富化任务编排与事务执行边界

情报富化由 EnrichmentService.run 统一驱动，按已注册富化器（Enrichers）的拓扑依赖顺序自动执行。系统默认执行序列为：vendor（厂商公告富化）→ epss（利用概率富化）→ kev（在野利用富化）→ poc（验证代码富化）→ patch（修复补丁富化）→ version（多分支版本区间富化）。其中，poc、patch 与 version 富化器显式声明依赖于 vendor 富化器产出的官方参考链接与维护方元数据；当调用方仅请求执行单项富化（如仅请求 version）时，编排器会自动检测并补入前置 vendor 任务。每个富化任务依次调用 investigate 获取材料、生成领域对象，随后针对目标漏洞执行跨源冲突检测、逐声明核验（evaluate_claim）与知识采纳，并持久化保存执行状态、关联 Claim/Evidence/候选 ID、错误详情、重试标志及执行耗时。若任一富化器在领域对象写入阶段发生异常，系统立即回滚该富化器的领域事务，同时完整保留已采集的 RawDocument 原文与 FAILED 审计记录。

5.3 多维深度富化机制设计

5.3.1 CVSS 严重性校验与 CWE 弱点映射

系统完整保存各来源提供的 CVSS 版本（如 v3.1、v4.0）、原始向量字符串（Vector String）、基础分值（Base Score）、评估机构（Provider）与时间戳[4]。在转换为待核验声明时，系统自动校验向量字符串与分值的一致性；若来源未提供评分，系统严格保留未知状态，绝不由大语言模型根据自然语言描述

臆造分值。同理，CWE 富化严格保留来源给出的弱点分类编号（如 CWE-77 命令注入、CWE-502 反序列化漏洞），帮助分析人员理解漏洞机理，且在来源缺失 CWE 时禁止模型随意补号[5]。

5.3.2 多维护分支影响版本与修复版本解析

版本富化器完整保留上游原始范围表达式及 OSV 结构化事件，并严格在“包生态（ecosystem）+ 精确发行包名（package）+ 维护分支（branch）”三维作用域内执行解析与比对。针对 OSV 规范中的特殊事件 introduced="0"，系统按该生态标准语义将其解析为当前分支无明确下界（即自该分支初始版本起受影响），而非字面版本号 0；对于语法不完整或无法解析的范围表达式则诚实标记为未知。当同一漏洞涉及多个并行维护分支（如 0.3.x 与 1.x）时，系统将各分支的受影响区间与修复版本独立存储，确保下游资产比对能够精准锁定所属分支的修复版本，并防止将上游源码仓库版本直接误用于采用独立回移补丁的下游发行包。

5.3.3 授权资产关联与固定快照封存

系统通过 get_asset 与 inspect_component_version 读取授权登记资产的包名、生态、版本及环境属性，并封存为 VersionObservation。后续版本比较与风险分析使用同一份资产快照。

5.3.4 PoC 验证状态与补丁（Patch）状态分级语义

针对公开 PoC 与修复补丁情报，系统严格区分“发现候选线索”、“静态关联确认”与“实际利用/应用验证”，避免将公开仓库中的同名未验证脚本误报为已在本地环境验证成功的利用链。表 7 给出了 PoC 富化的四级状态语义与判定边界。同理，补丁情报细分为官方修复版本声明（FIXED_VERSION）、公开补丁代码可用性（PATCH_AVAILABLE）与本地资产补丁已应用状态（PATCH_APPLIED）三类独立声明，各自绑定对应的核验依据。

表 7 PoC 情报富化状态分级语义、判定依据与安全边界

PoC 状态分级标识	报告与界面展示语义	系统核验判定依据	严格安全语义边界
POC_CANDIDATE	PoC 候选线索	通过公开仓库元数据或有限 README 检索发现提及目标 CVE/GHSA 的候选仓库，但尚缺权威直接证据支持	仅作为分析人员排查线索展示，不进入已确认事实列表，不触发高危利用加权
POC_LINKED / CONFIRMED	已确认漏洞关联	具备合格的官方公告引用或至少两组独立高质量证据显式支持该材料与目标漏洞直接关联	确认该公开材料与目标漏洞存在真实技术关联，但不等价于已在本地目标资产上复现利用
INSUFFICIENT / NOT_FOUND	当前检索范围未发现合格支持	在当前已接入公开源与限定检索范围内未找到满足显式关联条件的 PoC 材料	客观反映当前受控检索范围的证据状态，不武断声称全网绝对不存在未公开利用代码
EXPLOIT_VERIFIED	利用已实证确认	具备授权靶场复现回执或 CISA KEV 等权威机构确认的真实利用验证材料	系统静态元数据富化不自动签发本地资产级利用确认，须由显式权威证据支撑

5.3.5 学术论文、技术博客关联与 Evidence 绑定

系统利用本地 384 维 MiniLM 向量索引计算安全博客、arXiv 学术论文与目标漏洞描述之间的有界余弦相似度，高效召回相关技术分析文献候选，并完整保存文献标题、URL、摘要与关联理由。在此基础上，EvidenceService 将候选材料与具体待核验声明（Claim）、RawDocument 哈希、原文定位指针（locator）及支持/反证立场显式绑定，只有通过对象身份与作用域核对的材料才能成为正式证据引用。

5.4 富化执行流水线与跨源血缘消歧实证

图 5 上半部展示富化任务编排，下半部说明来源归组与分支比较如何连接：多个数据库中的相关记录先核对共同出处，再与目标包及对应维护分支关联。具体运行结果在第九章展开。



图 5 多维情报富化执行流水线与跨源证据血缘（Lineage）消歧机制实证

5.5 富化领域输出与下游消费契约

表 8 汇总了七大富化维度的领域输出对象与下游问答模块的消费契约。通过将“结构化字段提取”、“声明级证据核验”与“本地资产适用性比对”分层管理，系统既保证了富化知识的广度，又确保了最终问答引用的严谨性。

表 8 七大情报富化维度领域输出与下游消费契约

富化维度	领域输出对象与处理能力	下游问答与分析消费契约
CVSS 严重性评分	保存多源 CVSS v3.1/v4.0 分值、向量字符串、评估机构与时间；校验向量与分值一致性并转换为 Claim/Evidence	经声明核验后供 Security Analysis Agent 评估基础严重性；缺失评分保持未知，禁止模型估算
CWE 弱点分类	提取并保留官方来源给出的 CWE 编号与弱点类别映射（如 CWE-77、CWE-94、CWE-502）	用于解释漏洞成因与技术机理；来源未提供 CWE 时严格置空，禁止模型根据文本猜测补号
影响与修复版本区间	解析保留原始范围表达式与 introduced / fixed / last_affected 结构化事件，按多维护分支独立建模	在精确匹配包生态（如 PyPI）与包名后，与固定资产版本快照逐分支比对并锁定对应分支修复版本

富化维度	领域输出对象与处理能力	下游问答与分析消费契约
受影响登记资产	通过授权库存工具读取组件包名、版本、环境与暴露面，封存为不可变的 VersionObservation 快照	作为整次调查唯一合法的资产比对基准，确保核验、风险评级与门禁审查引用同一版本状态
PoC 与 Patch 情报	搜集公开 PoC 仓库与补丁链接，区分候选线索（Candidate）、静态关联确认（Linked）与补丁状态三元组	仅经显式证据核验确认关联的 PoC/Patch 方可进入已确认引用链；修复动作须绑定 FIXED_VERSION 证据
Evidence 与血缘图谱	构建 RawDocument → SourceObservation → Evidence → Claim 四层引用链，计算跨源共同出处 lineage_key	AnswerComposer.eligible() 强制要求公开引用的证据必须同声明、同作用域、VALID 且当前有效
论文与技术博客关联	提取 arXiv 论文与安全博客元数据、切分段落并构建 384 维本地 MiniLM 语义向量索引	通过 semantic_search 召回跨文档技术背景候选，正式事实采纳仍须通过声明级适用性核验

第六章 情报问答模块设计

6.1 问答模块设计目标

情报问答模块面向安全分析人员的自然语言复杂查询，负责将高层安全问题转化为受控的多智能体调查任务，支持跨文档语义检索与多跳关联推理，精准回答漏洞影响范围、多分支修复建议、关联技术资料及本地登记资产的风险优先级，并以结构化、可审计的 AnswerEnvelope 交付最终结论。

6.2 输入上下文预检与混合语义检索设计

问答入口接收用户的原始自然语言问题以及显式提供的漏洞标识、目标组件包名、包生态和部署版本上下文。任务目录原生支持单漏洞全景概览、指定组件版本受影响判定、以及授权登记资产风险与优先级评估等核心调查模式。在启动重型多智能体调查前，输入预检器首先校验当前查询意图所需的必需上下文参数：若用户询问特定组件或资产是否受影响但未提供版本号且库存无对应记录，系统立即返回 NEED_CONTEXT 状态及 missing_fields 清单，引导用户补充关键条件。

在知识检索层面，系统采用“精确结构化检索 + 384 维本地稠密向量检索”的混合检索架构：关键词与精确索引负责处理 CVE/GHSA 编号、生态名称与组件包名；基于本地 FastEmbed / MiniLM 的 384 维向量索引通过有界余弦相似度召回跨文档的博客分析与学术论文片段。检索相关度仅用于为 Investigation Agent 提供候选调查线索，任何候选文本能否作为安全事实采纳，均由下游 Verification Agent 的声明核验规则决定。

6.3 自然语言调查工作流与状态机设计

图 6 展示自然语言调查工作流。参数齐全的请求异步受理后，依次完成规划、取证、核验、资产分析和 Gate 验收。调查工作台提供新建表单、历史读取、阶段进度、角色产物及答案面板，通过 HTTP 轮询更新真实阶段事件；终态停止轮询，并分别展示调查状态、门禁状态和答案状态。详细发布原则见第 7.7 节。



图 6 AegisAI 自然语言深度问答工作流、Integration Gate 裁定与 AnswerEnvelope 状态机

6.4 AnswerEnvelope 结构化封存输出设计

AnswerComposer 根据 Gate Context 与角色产物生成 AnswerEnvelope。summary 概括交付状态，verified_claims 和 citations 保存采纳事实及原文定位，disputed_claims 保留争议，asset_snapshot 与 risk_assessment 记录资产及风险依据。recommended_actions 中的具体修复版本须绑定本次答案接受的 FIXED_VERSION 声明。

6.5 任务支持范围与安全交互边界

系统支持单漏洞概览、指定组件版本判定与登记资产风险分析。超出注册工具或单目标范围的查询会保留原始目标并报告范围缺口；证据缺失、冲突和上下文不足分别由对应状态表达。

6.6 跨文档多跳关联推理机制

针对复杂安全查询，AegisAI 的跨文档关联推理并非依赖大模型的黑盒自由联想，而是沿着显式领域实体链逐步推进并校验：

形式化定义 4：跨文档五跳可验证关联推理链（5-Hop Grounded Reasoning Chain）

Hop 1 (别名对齐)：CVE-ID ⟵alias_cluster⟶ GHSA-ID / OSV-ID (跨源同一漏洞身份聚合)

Hop 2 (生态映射)：GHSA/OSV 公告 ⟶ecosystem_scope⟶ Package(PyPI, name) (锁定下游发行包空间)

Hop 3 (血缘消歧)：{Obs_NVD, Obs_OSV, Obs_GHSA} ⟶origin()⟶ LineageKey (消除同源转载重复计数)

Hop 4 (分支匹配)：AssetSnapshot(v_inst) × BranchRanges{[v_intro, v_fix)} ⟶match_version⟶ Branch_k

Hop 5 (处置绑定)：Branch_k.fixed_version × VerifiedEvidence ⟶eligible()⟶ RecommendedAction

说明：每一跳推理由对应的领域对象标识、原文定位指针与 SHA-256 哈希锚定，安全分析人员可从最终修复建议逆向回查任意中间推理环节。

第七章 关键技术实现

7.1 工程技术栈选型与依据

AegisAI 采用模块化、强类型、全链路可审计的现代工程技术栈。接口层基于 FastAPI 提供遵循 OpenAPI 规范的类型化异步服务；数据契约层基于 Pydantic v2 与 JSON Schema 实现模型生成结果的严格结构化校验；持久化层采用 SQLAlchemy 2.0、Alembic 与 PostgreSQL 保障事务一致性与审计留存；知识检索层结合 FastEmbed/ONNX 本地 MiniLM 向量模型与精确索引实现离线可控的混合检索；执行编排层则采用自研 DAG Runtime 与 Tool Gateway[6][7][8]。表 9 汇总了系统各层次的实际技术选型、选择依据与工程实现要点。

表 9 AegisAI 系统各层次技术选型、设计依据与实现要点

系统架构层次	实际技术选型	核心选型依据	工程实现要点与安全边界
HTTP 服务与接口层	Python 3.11+、FastAPI	原生异步支持、强类型路由契约、自动生成 OpenAPI 规范及清晰的 HTTP 状态码语义	实现 202 异步受理、幂等键冲突拦截（409）及 NEED_CONTEXT 预检响应
数据契约与校验层	Pydantic v2、JSON Schema	高性能严格模式（strict=True）验证、枚举与嵌套结构约束、精确字段路径错误提取	执行格式与类型强校验；字段级错误自动转为 schema_feedback 供 Planner 修正
持久化与事务层	SQLAlchemy 2.0、Alembic、PostgreSQL	支持 ACID 事务、复杂关系外键约束、版本化 Schema 迁移及 JSONB 审计快照存储	完整保存 RawDocument、Observation、Claim、Evidence、Artifact 与封存答案
混合知识检索层	FastEmbed / ONNX Runtime、本地 MiniLM（384 维）、精确索引	支持纯本地离线推理、无外部 API 数据泄露风险，兼顾精确编号匹配与跨文档语义召回	CVE/GHSA/包名走精确索引，博客与 arXiv 论文走 384 维有界余弦相似度检索

系统架构层次	实际技术选型	核心选型依据	工程实现要点与安全边界
模型统一调用网关	自研 Model Gateway、Ollama 兼容适配器	将上层智能体业务逻辑与底层大模型供应商解耦，统一管理超时、重试与 Token 审计	文本生成与 Embedding 独立配置；显式记录 provider、model、digest 与 is_mock 标志
智能体任务运行时	自研 DAG Runtime、Tool Gateway	精细控制拓扑依赖、并发度、工具白名单、读写/网络权限及子任务超时生命周期	支持必需任务确定性补齐、上游失败阻断传播与细粒度 ToolReceipt 审计回执
前端与工作台层	JavaScript ES modules、History Router、Node 同源代理	共用类型化 REST 数据，按页面组织总览、详情与调查交互，保留清晰的状态语义	总览指标与趋势、资产/复核详情、漏洞分页排序、Ctrl+K 全局搜索；调查面板支持历史读取、阶段与证据展示
质量与契约验证层	pytest、Node 测试套件、TypeScript 接口契约校验	覆盖核心核验算法、API 端到端契约、数据库事务回滚与前后端协议一致性	覆盖核验规则、计划约束、API 数据结构及前后端协议；实际测试记录集中列于第十章

7.2 Model Gateway 统一模型调用网关

Model Gateway 统一封装文本生成、结构化 JSON 生成、Embedding 向量化与服务健康检查接口，并在每次调用时自动记录 provider、model、request_id、trace_id、调用耗时、Token 消耗（usage）、错误详情及 is_mock 标记。Planner 的模型输出必须依次通过 JSON 语法解析、JSON Schema 校验、Pydantic 严格模型校验以及业务计划合法性校验（validate_investigation_plan）后方可进入 Runtime；任何字段缺失或被拒计划均会转化为结构化的 schema_feedback 与 rejected_context 上下文，支持受限预算内的二次自愈修正。表 10 展示了 Model Gateway 各调用阶段的处理机制与真实性保障约束。

表 10 Model Gateway 调用生命周期与真实性保障约束

网关调用阶段	核心工程实现行为	安全与真实性保障约束
① 请求入口预检	校验提示词消息结构、目标 JSON Schema 定义、temperature 与 max_tokens 等受限参数	拦截超长输入与非法参数；业务查询仅可使用既定模型能力，严禁运行时篡改进程级安全配置
② 适配器路由选择	根据 ModelConfig 选择已登记的生成适配器（如 Ollama Qwen2.5）与向量适配器（MiniLM）	文本生成与 Embedding 通道完全解耦；对当前适配器未声明支持的能力在发起网络调用前直接拒绝
③ 响应解析与复验	执行 64KB 字节边界检查、JSON 解析、JSON Schema 验证、Pydantic strict=True 校验与业务规则检查	严格区分“JSON 语法/结构合法”与“安全事实成立”，格式通过后仍须交由 Verification 角色核验
④ 审计日志留存	持久化保存模型名称、权重摘要指纹（digest）、is_mock 标志、响应耗时、Token 统计与 trace_id	真实评测与模拟测试（Mock）在数据库层通过 is_mock 严格隔离，确保实机质量评估数据真实纯净

7.3 自研 DAG Runtime 与 Tool Gateway 权限管控

自研 DAG Runtime 负责校验任务有向无环图的拓扑依赖与环路，按就绪队列调度执行任务并持久化 Artifact 与 ToolReceipt。任务在整个生命周期内沿 CREATED → PENDING → READY → RUNNING → SUCCESS / FAILED / WAITING_REVIEW / BLOCKED 状态机迁移，所有状态跃迁均写入 TaskTrace。Tool Gateway 仅允许调用服务端显式注册的白名单工具，并按“只读查询、内部状态写入、受控外部网络访问”三类权限以及最大任务数、图深度、单次超时和总预算进行硬性护栏管控。表 11 给出了 Runtime 任务状态语义与审计记录机制。

表 11 DAG Runtime 任务状态机语义与审计追踪机制

任务状态枚举	运行时状态语义	持久化记录与下游调度约束
CREATED / PENDING / READY	任务节点已创建、正在等待前置依赖完成、或前置依赖已全部满足进入就绪队列	TaskTrace 记录每次状态跃迁时间戳；存在未完成前置依赖时严禁提前调度执行
RUNNING	当前工具调用或智能体角色推理正在受控执行中	绑定开始时间、调用参数摘要与超时保护器；支持响应外部取消（Cancel）信号
SUCCESS	工具或角色执行正常返回，且产出物通过运行时结构检查	生成带哈希的 ToolReceipt / Artifact 并解锁下游依赖节点；不直接等同于安全事实已确认
FAILED / WAITING_REVIEW / BLOCKED	执行发生异常、触发人工复核条件、或因上游必需节点失败而被级联阻断	完整保存错误栈、未解决事项（unresolved_items）与部分回执，阻断下游依赖节点带病运行

7.4 核心源码深度解析

表 12 给出三个关键机制的源码位置与输入输出，后续小节结合代码说明任务补齐、来源核验以及版本与答案过滤。

表 12 AegisAI 核心源码函数位置、输入输出契约与安全边界

核心函数与代码位置	输入与输出契约	核心职责与安全边界控制
task_requirements agents/investigation/task_invariants.py:31	PlannerContext → RequiredTask 集合	从原始查询意图与显式上下文中独立提取必需执行的资产、版本与证据任务
complete_required_tasks agents/investigation/task_invariants.py:52	候选计划 + 上下文 + 工具目录 → 补齐后计划	在只读权限、完备参数与唯一上游依赖条件下自动补齐缺失必需任务，并触发全量复验
schema_feedback agents/investigation/schema_feedback.py:10 rejected_context agents/investigation/retry_context.py:8	Schema 异常与被拒计划 → 结构化修正上下文	提取精确字段路径错误反馈给 Planner 进行自愈重试，严格限制最多 2 次尝试

核心函数与代码位置	输入与输出契约	核心职责与安全边界控制
origin enrichment/evidence.py:19	SourceObservation → lineage_key 字符串	识别跨源记录背后的共同 GHSA 维护方公告出处，防止同源转载被重复计为独立证据
evaluate_claim enrichment/rules.py:40	当前有效证据列表 → 核验状态与独立血缘组	综合裁定 CONFIRMED / CONFLICT / INSUFFICIENT_EVIDENCE，对 PoC 施加独立显式引用约束
assess_risk agents/analysis/rules.py:186 assess_priority assets/priority.py:5	核验结果 + 资产快照 → 本地风险与优先级	先执行 match_asset 与 match_version，前置核验未确认时强制保持 UNKNOWN 与 REVIEW_REQUIRED
coverage integration/objective.py:28	Objective 契约 + Analysis 产物 → 目标覆盖结果	检查范围、资产、风险与处置建议等必要目标项是否全部被有效回答
IntegrationGateEvaluator integration/evaluator.py:33 AnswerComposer orchestration/composer.py:115	IntegrationContext → Gate 结果与 AnswerEnvelope	执行六维门禁审查与 eligible() 证据发布过滤，封装不可变的可溯源结构化答案

7.4.1 服务端必需任务补齐与三层计划复验

形式化定义 1：服务端必需任务不变量与确定性补齐算子

R_req(c) = task_requirements(c) = { t_lookup, t_asset, t_version, t_evidence | 由原始查询意图与显式上下文 c 唯一确定 }

G_completed = complete_required_tasks(G_cand, c, Catalog) = G_cand ∪ { t ∈ R_req(c) \ V(G_cand) | Auth(t, c) ∧ UniqueDep(t, G_cand) }

Valid(G_completed, c) = CheckSchema(G_completed) ∧ CheckScope(G_completed, c) ∧ CheckDAG_Acyclic(G_completed) ∧ (R_req(c) ⊆ V(G_completed))

说明：仅当缺失任务属于注册目录中的只读工具（Auth 通过）、所需输入参数在上下文 c 中完整存在且上游依赖节点可唯一解析（UniqueDep）时，complete_required_tasks 才执行确定性补齐，随后必须重新通过完整三层校验链 Valid(G_completed, c)。

task_requirements 先确定请求必需步骤，complete_required_tasks 仅对输入和依赖可安全解析的缺失节点执行补齐。原始计划与补齐后的计划均须通过以下复验链。

核心源码片段 1：计划 Schema 验证、Pydantic 严格反序列化与业务完整性复验 (backend/app/agents/investigation/)

```
# 第 1 层：JSON Schema 结构与枚举约束验证，拦截非法字段与越界参数
validator.validate(value)
# 第 2 层：限制 64KB 最大载荷并通过 Pydantic v2 strict=True 执行强类型反序列化
encoded = json_bytes(value, 65536).decode()
output_model.model_validate_json(encoded, strict=True)
# 第 3 层：校验任务作用域、工具白名单、DAG 拓扑无环性、必需任务覆盖与重试预算
validated = validate_investigation_plan(
    InvestigationPlan.model_validate_json(encoded), context
)
```

三层检查依次约束输出结构、字段类型和业务依赖。只有成功构造 ValidatedPlan 的计划才能进入 Runtime；失败反馈保留原计划及字段路径，最多进行两次规划尝试。

7.4.2 跨源血缘归组与声明支持度裁定

EvidenceService.add 将原文、来源记录、作用域和定位指针绑定到声明。origin() 核对官方 GHSA 转录路径，识别共同出处并生成归组键；evaluate_claim 再按规范化声明值、证据立场和来源组裁定支持程度。核心归组代码如下。

核心源码片段 2：规范化声明值比对与跨源独立血缘组统计 (backend/app/enrichment/rules.py)

```
# 筛选当前有效、立场为 support 且规范化值完全匹配的证据项
supports = [x for x in current
    if x.get("stance") == "support"
    and canonical_value(kind, x.get("value") or {})
        == canonical_value(kind, value)]
# 按 origin() 计算的 lineage 血缘键去重归组，统计真正独立的官方/权威支持源数量
groups = sorted({x.get("lineage") or "unresolved-origin"
    for x in supports if x.get("explicit")
    and x.get("authority") in ("official", "authoritative")})
```

归组集合统计的是共同出处，而非 URL 数量。核验时先保留支持与反证并存的冲突；无反证时，再检查官方直接支持或独立权威支持条件。PoC 关联还需满足其显式引用要求。

7.4.3 资产适用性前置核验与答案证据发布过滤

assess_risk 将资产快照与核验产物封装为 AnalysisContext，强制先执行 match_asset 与 match_version；当前置条件未满足时保持默认风险 UNKNOWN 与优先级 REVIEW_REQUIRED。在最终构建 AnswerEnvelope 时，AnswerComposer 通过 eligible() 函数对拟公开引用的证据执行严格准入过滤：

核心源码片段 3：AnswerComposer 公开证据准入过滤函数 eligible()
(backend/app/orchestration/composer.py)

```
01  def eligible(e, claim):
02      return (e.claim_id == claim.claim_id
03          and e.scope_key == claim.scope_key
04          and e.integrity_status == "VALID"
05          and e.is_current and e.hash and e.raw_document_id
06          and e.observation_id and e.source_id
07          and e.authority_level in ("official", "authoritative")
08          and e.directness == "direct" and e.stance == "support"
09          and not e.exclusion_reasons)
```

eligible() 强制要求公开展示的每条证据必须与目标声明的 claim_id 和 scope_key 完全一致，且同时满足完整性校验通过（VALID）、当前有效（is_current）、具备完整 SHA-256 哈希与原文/观察/来源三级外键、属于官方或权威机构的直接支持证据且无任何排除理由。未确认的声明被严格隔离在 disputed_claims 中，确保交付给用户的每一条结论与修复动作都具备坚实、可回查的证据支撑。

7.5 类型化调查 REST API 与前后端契约

系统通过 8 个核心 RESTful 接口对外提供完整的多智能体安全调查服务，如表 13 所示。当请求通过参数与权限校验后，POST /api/investigations 返回 HTTP 202 Accepted 及唯一调查标识；客户端随后可按需轮询状态、执行轨迹、角色产物、门禁审查详情及最终封存答案。当指定组件评估缺少必需版本号时，入口直接返回 NEED_CONTEXT，并通过 missing_fields、investigation_created=false 与 execution_mode 字段向调用方清晰说明缺失条件。

表 13 AegisAI 调查服务核心 REST API 接口契约

HTTP 方法	接口路由路径	核心业务功能与返回契约
POST	/api/investigations	提交自然语言安全调查请求；参数完备时创建异步调查任务并返回 HTTP 202，缺失关键上下文时返回 NEED_CONTEXT
GET	/api/investigations/{id}/status	查询指定调查任务的当前执行阶段（Planning / Investigating / Verifying / Analyzing / Gate）与终态
GET	/api/investigations/{id}/trace	读取完整 DAG 调度轨迹（TaskTrace）、Planner 重试记录及各节点状态迁移时间戳
GET	/api/investigations/{id}/artifacts	读取 Investigation、Verification 与 Security Analysis 三个角色生成的强类型结构化产物
GET	/api/investigations/{id}/integration	读取 Integration Gate 六维门禁审查明细、目标覆盖报告与汇总状态
GET	/api/investigations/{id}/answer	幂等读取已封存的 AnswerEnvelope 结构化答案（含已确认事实、原文引用、争议声明、风险评级与警告）
POST	/api/investigations/{id}/cancel	向正在运行的调查任务发送受控取消请求，安全回收子任务并保存取消审计状态
GET	/api/investigations/history	按当前认证拥有者（Owner）权限范围分页查询历史调查列表与摘要状态

7.6 幂等控制、访问隔离与异常容错处理

幂等键与 owner_id 共同约束请求复用：相同拥有者、相同键及相同请求返回既有调查；请求体不同则返回 HTTP 409。封存答案按调查标识读取，新调查建立独立产物链；异常任务保留错误状态和部分回执，供下游判断是否继续。

7.7 Integration Gate 裁定实现与答案发布原则

IntegrationGateEvaluator 在深度校验通过的不可变 IntegrationContext 上依次调用六大类注册规则，汇总生成门禁状态（integration_status），并与 AnswerComposer 的答案状态（answer_status）协同控制最终交付行为。表 14 总结了五种门禁汇总状态的语义及对应的答案发布原则。

表 14 Integration Gate 汇总状态语义与 AnswerEnvelope 发布控制原则

Gate 汇总状态	门禁审查结论含义	AnswerComposer 答案发布与字段控制原则
PASS	六维门禁检查全部无警告通过，原始查询的所有必要目标项均获充分支持	签发 COMPLETE 状态答案，完整发布已确认事实、引用链、风险评级与精确修复建议
PASS_WITH_WARNINGS	核心业务目标已满足且证据链有效，但存在非阻塞警告（如同源血缘 SHARED_SOURCE_LINEAGE）	签发 COMPLETE_WITH_WARNINGS 答案，正常交付核验结论与修复建议，同时在 warnings 中显式披露限制条件
HUMAN_REVIEW_REQUIRED	存在跨源版本范围实质冲突（CONFLICT）或高风险未决条件，需安全专家介入裁定	在答案中完整列出支持与反证双方的原文引用及冲突点，明确标识需人工复核，禁止输出武断结论
REPLAN_REQUIRED	当前任务图或已获取资料无法满足原始查询目标，存在工具或上下文缺口	如实返回未覆盖的目标项与缺失资料清单，保留已执行的轨迹供排查
FAILED	发生致命完整性违例、跨调查引用污染或核心必需任务执行失败	严禁将失败结果包装为正常安全结论发布，仅返回受控错误诊断与 Gate 阻断原因

第八章 传统安全分析与本项目机制对比

8.1 对照维度与分析基准说明

为清晰展现 AegisAI 相较于传统安全运营方式及普通单次大模型问答（Single-Turn LLM / Naive RAG）的技术优势，本章从多源信息获取、复杂任务编排、事实可信核验、资产风险判定以及过程审计留存五个核心维度开展系统性机制对比。

8.2 全流程核心机制对比分析

在传统安全应急响应中，分析人员需要手工检索多个漏洞库与 GitHub 公告，自行比对包管理器版本区间并撰写排查报告，不仅耗时费力，且极易因同源转载误判证据强度；而在普通单次大模型问答中，模型容易遗漏关键资产检查步骤或混淆不同维护分支的修复版本。AegisAI 通过“服务端必需任务不变量 + 跨源血缘消歧 + 资产快照分支比对 + 六维 Gate 验收”四重机制，实现了灵活性与确定性的有机统一，具体对比见表 15。

表 15 传统人工流程、普通单次大模型生成与 AegisAI 核心机制对比

对比维度	传统人工主导安全分析流程	普通单次大模型 / Naive RAG	AegisAI 多智能体可信调查系统
多源信息获取	人工逐一检索 CVE、NVD、GitHub 与技术博客，手工整理复制，时效慢且易遗漏	仅依赖静态预训练知识或简单文本块拼接，缺乏增量游标与原始字节级快照留存	7 大类异构情报源自动增量同步，Checkpoint 断点续采，RawDocument SHA-256 原文快照全留存
调查任务编排	依赖分析人员个人经验决定排查顺序，步骤交接无标准化结构契约	黑盒自由生成或单次 Prompt 规划，常因生成随机性遗漏资产读取或版本比对步骤	LLM 受约束 DAG 规划 + 服务端 task_requirements 必需任务确定性补齐 + 三层 Schema/拓扑复验
事实可信核验	人工交叉比对多个网页，难以快速识别不同平台公告背后的同源转录关系	按检索片段数量盲目汇总，极易将同源多次转载当作多源确认，或产生无出处幻觉评分	Claim/Evidence 显式建模 + origin() 跨源共同血缘消歧 + evaluate_claim 支持/反证冲突裁定

对比维度	传统人工主导安全分析流程	普通单次大模型 / Naive RAG	AegisAI 多智能体可信调查系统
资产风险判定	人工核对组件清单与版本号，面对多维护分支与回移补丁时易算错区间	容易混淆上游源码版本与下游 PyPI 包版本，或跨分支张冠李戴给出错误的升级建议	封存 VersionObservation 资产快照，精确核对包生态与多维护分支区间，规则化合成风险与优先级
过程留存与审计	依赖人工编写文档归档，过往结论难以按当时的外部情报与资产状态精确复现	仅输出一段非结构化自然语言文本，无工具回执、无原文定位指针，无法满足合规审计	全链路持久化 ToolReceipt、三角色 Artifact、Gate Trace 与不可变 AnswerEnvelope，支持幂等复查

第九章 系统实现与功能展示

9.1 实机运行环境与展示口径

本章结合冻结运行记录与现有 Web 前端展示监测、富化和调查问答。前端采用已接入的总览、资产详情和调查工作台页面；源码与 GitHub 前端分支核对，页面使用正式后端 API。C08/C09 沿用各一次真实调查记录；本次截图读取已有数据库结果。前端完整调查提交及缺上下文处理另有浏览器运行记录，索引见附录 E22。

9.2 多源情报监测与协同调查工作台效果展示

前端已实现总览驾驶舱、情报监测、漏洞富化、调查工作台、资产与复核详情及系统状态等页面。全局搜索可按 CVE、产品或资产进入相关页面，列表支持筛选与详情读取。图 7 展示新版情报监测中心的界面布局，其中采集量、增量与成功率为界面演示数据。

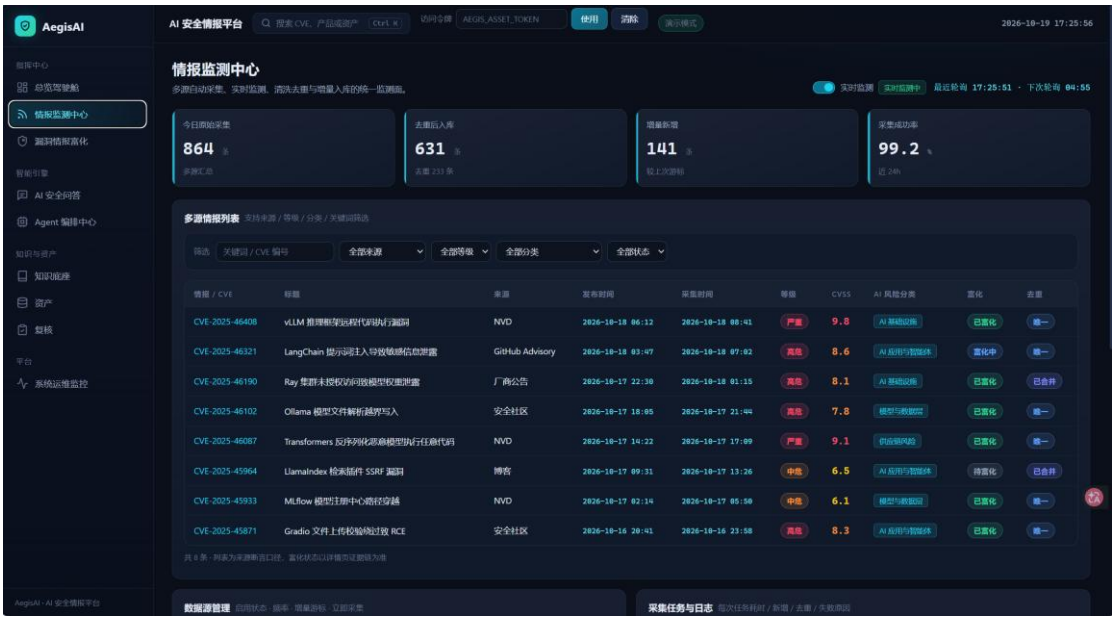


图 7 新版 Web 前端的情报监测中心（界面演示）

调查工作台提供新建调查表单、既有调查读取及阶段状态展示，并连接 Gate、答案与证据引用。图 8 为新版深色界面读取既有 C09 调查的画面：真实 API 模式保持选中，状态为完成并带警告；本次仅读取历史记录。



图 8 新版调查工作台的输入与既有调查完成状态

资产详情页连接登记组件、包生态、版本与风险快照，并提供风险变化、库存历史和资产复核页签。图 9 展示 langchain-core 1.2.0 的登记信息及既有风险记录。页面保留各快照的评估时间和不确定状态，与单次调查的临时核验结果分开呈现。复核详情页则将声明、证据和审计记录集中展示。

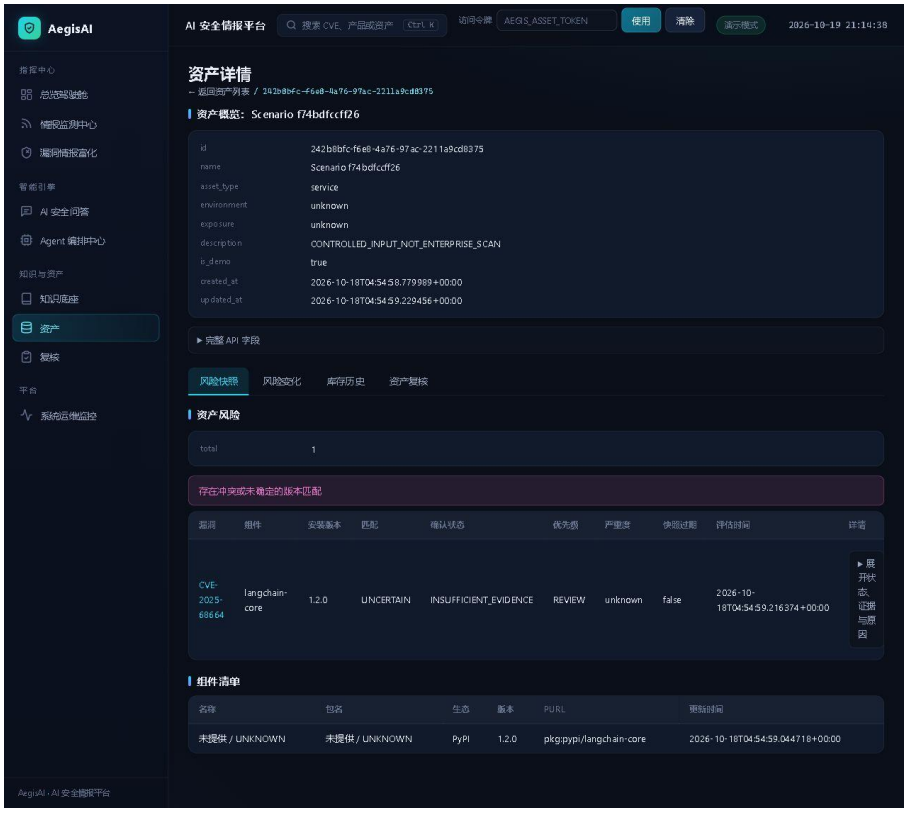


图 9 资产详情、组件版本与带时间戳的风险快照

表 16 汇总了系统在真实外部数据源采集与标准化入库阶段的代表性批次记录。系统对结构化漏洞记录提取完整别名、CVSS v3.1/v4.0 向量与 CWE 弱点分

类；对安全博客与学术论文则保留独立文档身份、原文快照与 384 维本地 MiniLM 语义向量索引，并对部分成功批次（PARTIAL）实施断点留存。

表 16 多源情报真实采集批次、标准化投影与知识底座入库效果

数据源与资料类别	采集适配器与同步机制	标准化领域对象与索引产出	实机运行效果与可追溯验证
NVD / OSV / GitHub 结构化漏洞与公告库	有界分页拉取与增量 Checkpoint 游标同步；支持 PARTIAL 批次状态隔离与断点续采	生成 RawDocument（含 SHA-256）、SourceObservation 与 NormalizedVulnerability，提取 CVSS、CWE 与多分支版本事件	标准化漏洞与多源观察记录成功入库，可由情报 API 与 get_vulnerability / get_claims 工具毫秒级读取（见 E08、E11）
Trail of Bits RSS 等安全社区技术博客	防 XXE 安全 XML 解析器提取标题、正文、发布时间与原文定位指针	构建 BlogArticle 领域对象，完成文本分段切分并生成 384 维本地 MiniLM 稠密向量索引	技术研究文章成功入库并支持 semantic_search 跨文档检索；严格保持文章身份独立，不强行伪造 CVE 关联（见 E09）
arXiv Atom API & 安全政策规范底座	按 AI 安全主题词拉取 Atom XML 元数据与摘要；遇到网络限流时自动记录失败批次并择机窄查询重试恢复	生成 ResearchPaper 知识对象与策略规则契约（如 reference-triage、asset-priority-v1），纳入统一混合检索底座	论文摘要与元数据成功入库并可被语义工具检索召回，验证了采集器的异常恢复与多模知识汇聚能力（见 E09、E14）

9.3 情报深度富化与跨源证据连接效果

表 17 展示历史 PyTorch 情报 API 的字段投影，说明产品、CVSS、CWE 与版本事件如何进入结构化结果。字段提取和声明核验分别记录；下两节再以 C08、C09 展示资产问答中的实际使用过程。

表 17 情报 API 多源漏洞记录标准化投影与核验分层展示（PyTorch 案例）

富化与投影维度	CVE-2022-45907 标准化投影	CVE-2025-32434 标准化投影	数据治理与抗幻觉设计体现
数据来源与受影响产品	汇聚 NVD 与 OSV 双源记录；受影响产品明确解析出 PyPI / torch	采集自 NVD 官方记录；上游原始 CPE 未给出结构化包名时保持受影响产品为空	严格忠实于原始观察记录，绝不跨漏洞借用或由模型凭空猜测产品名称
CVSS 多版本评分断言	完整保留 CVSS v3.1/9.8 来源断言及多机构评估记录	同时保留 CVSS v3.1/9.8 与 CVSS v4.0/9.3 两套标准向量与分值断言	按评分版本、评估机构（Provider）与观察时间戳独立存储，不作简单均值涂抹
CWE 弱点分类映射	精确提取 CWE-77（命令注入）、CWE-94（代码注入）	精确提取 CWE-502（不可信数据反序列化）	完整保留官方弱点分类，支撑漏洞成因解释
版本区间解析与核验分层	成功解析 OSV 事件 introduced=0（无下界）至 fixed=1.13.1；清晰区分“解析成功”与“核验确认”	上游记录尚未公布结构化版本区间时保持为空值，核验状态标注为来源断言待核实	将“字段语法解析状态”与“声明级证据核验状态”严格分离，防止未核实数据直接触发告警

9.4 典型案例一（C08）：维护分支精准匹配与策略验收分析

案例 C08（调查 ID：78eabee2-b88b-4b39-b39d-7536f4350b41）测试系统在多维护分支场景下的精确版本比对与风险评估能力。用户输入的自然语言问题为：“按 benchmark-reference-triage-v1 评估此演示资产对 CVE-2025-68664 的风险与优先级”，显式绑定登记资产为 PyPI/langchain-core 1.2.0。表 18 展示了系统实际返回的 HTTP 响应核心字段及其工程解析。

表 18 案例 C08（CVE-2025-68664 / langchain-core 1.2.0）实机 HTTP 响应与技术解析

响应模块与字段路径	系统实机 HTTP 返回值摘录	技术机制解析与验证结论
调查标识与执行耗时	investigation_id: 78eabee2-b88b-4b39-b39d-7536f4350b41 端到端壁钟耗时：52.50 秒（含本地模型规划、工具取证与轮询）	异步 202 受理后完整历经四角色执行与六维门禁验收，生成 3 份角色 Artifact 与完整证据引用

响应模块与字段路径	系统实机 HTTP 返回值摘录	技术机制解析与验证结论
版本比对与修复建议 (/recommended_actions)	version_match_status: AFFECTED matched_range: ">= 1.0.0, < 1.2.5" fixed_version: "1.2.5"	上游公告 GHSA-c67j-w6g6-q2cm 同时存在 <0.3.81 与 >=1.0.0,<1.2.5 两个分支[9]；系统精准识别 1.2.0 属于 1.x 分支并给出 1.2.5 升级建议，未发生跨分支错配
风险与优先级评估 (/risk_assessment)	risk_level: HIGH | priority: P2 verification_status: CONFIRMED conclusion_scope: ACCEPTED	内置规则基于当前接受的受影响状态与严重性事实生成 HIGH / P2；指定策略的适用边界在第 12.2 节统一说明
门禁与答案终态 (/integration & /answer)	integration_status: PASS_WITH_WARNINGS answer_status: COMPLETE_WITH_WARNINGS warnings: ["SHARED_SOURCE_LINEAGE"]	origin() 成功识别多条观察记录源自同一 GHSA 维护方公告，在确认官方直接支持的同时主动发出同源血缘提示
目标覆盖审计 (/objective_coverage)	risk: SATISFIED | priority: SATISFIED	记录当前编码目标项的覆盖结果；用户命名策略与实际采用规则的对应关系另行保留

9.5 典型案例二（C09）：公告范围差异识别与计划自愈恢复

案例 C09（调查 ID：37a0d8a1-3bfd-49f8-b841-21009fed28b8）检验系统在模型初次规划存在格式缺陷时的自动化自愈能力，以及面对上游公告结构化字段与正文描述不一致时的可追溯表现。用户问题为：“vllm 版本 0.29.0 是否受 CVE-2026-105752 影响？”（对应公告 GHSA-935w-9g4m-p28p[10]）。表 19 展示了该次调查的执行轨迹与范围分析。

表 19 案例 C09（CVE-2026-105752 / vLLM 0.29.0）计划自愈与范围比对实录

关键考核环节	实机运行记录与原文证据摘录	系统处理机制与工程价值
Planner 计划自愈恢复 (/trace)	Attempt 1：模型生成的 tasks[0] 与 tasks[1] 缺失 acceptance_criteria 字段，被 Schema 校验器拦截；Attempt 2：经 schema_feedback 字段路径反馈后二次生成通过三层复验，总耗时 46.50 秒	实证验证了 3.3 节与 7.4.1 节设计的“字段级错误反馈 + 受限重试自愈”机制，无需人工干预即可从生成格式错误中自动恢复
公告结构化范围字段 (/vulnerabilities/0)	vulnerable_version_range: "< 0.30.0" patched_versions: ">= 0.30.0"	系统版本富化与初筛引擎读取标准结构化范围字段，判定 0.29.0 < 0.30.0（in_range=true），推荐升级至 0.30.0
公告正文描述字段 (/description)	正文 Affected 小节记载："vLLM <= 0.25.1 (confirmed on 0.25.1)"，同时提及 Harmony /v1/responses、prefix caching 与 cache_salt 等触发前提	引用保留结构化范围与正文位置，可直接检查两种上界及部署条件。本次按结构化字段比较；范围差异的适用性仍需复核
核验与交付状态 (/answer)	integration_status: PASS_WITH_WARNINGS answer_status: COMPLETE_WITH_WARNINGS risk_level: MEDIUM | priority: P3 warnings: ["SHARED_SOURCE_LINEAGE"]	完整封存 16 条证据引用与原文 SHA-256 哈希，确保所有判定依据透明可查

9.6 历史端到端调查记录

表 20 保留早期 vLLM 0.6.5（GHSA-hjq4-87xh-g4fv）调查记录[11]。该记录针对 V0 引擎与 PyNcclPipe KV cache 传输条件，耗时 68.656 秒，返回 PASS / COMPLETE，并给出 HIGH / P1 与升级至 0.8.5 的建议。它用于说明当时版本的产物交接过程，具体适用条件随原公告保存。

表 20 vLLM 0.6.5（GHSA-hjq4-87xh-g4fv）全链路多智能体调查执行实录

调查执行阶段	系统实际输入与内部处理行为	可审计产出与验证结论
① 用户查询绑定	输入明确漏洞标识、登记资产、组件（vLLM）及部署版本 0.6.5	服务端锁定完整业务目标与 RequiredTask，禁止将资产风险查询降级为普通概览
② Planner 自愈规划	本地 Qwen2.5 生成候选计划；首次因 QUERY_SCOPE_MISMATCH 被拒，二次修正后通过复验	验证了作用域校验器对偏离原始目标计划的精准拦截与重试恢复能力
③ Investigation 取证	按拓扑顺序调用漏洞查询、证据拉取与授权资产版本检测工具	成功提取 >=0.6.5, <0.8.5 受影响范围，并封存固定 VersionObservation(0.6.5)
④ Verification 核验	在固定证据快照上校验 5 项核心安全声明的支持度与来源权威性	5 项核心 Claim 全部获得 CONFIRMED 确认，原文 SHA-256 哈希与定位指针完整闭合
⑤ Security Analysis	比对固定版本 0.6.5 与已确认区间 [0.6.5, 0.8.5)，结合 CVSS 3.1/9.8 评估风险	判定版本受影响（AFFECTED），输出本地风险 HIGH、优先级 P1，推荐升级至 0.8.5
⑥ Gate & Envelope	执行六维门禁审查并封装持久化 AnswerEnvelope（总耗时 68.656 秒）	门禁裁定 PASS，答案状态 COMPLETE，重复调用 GET /answer 返回完全一致的封存结果

第十章 测试验证与性能分析

10.1 测试验证体系与评价目标

验证由工程回归、模块运行案例、49 题自动匹配和小样本配对对照组成。工程测试检查契约与实现行为，业务案例核对原始证据与具体输出，自动评分则按冻结规则统计字段匹配。

10.2 工程契约与自动化回归测试

历史证据链修订版完成后契约单元回归测试共计 1,426 项，该套测试运行于独立 PostgreSQL 测试库和 Mock-LLM 模型环境，失败和跳过均为 0；对应前端测试 23 项通过，TypeScript 检查通过并核对 42 个 HTTP 契约操作。来源独立性修复新增 12 项专项通过，88 项关联测试完成通过覆盖，其中 1 项在补齐测试数据库配置后单独补跑。各组版本和范围见表 23，不合并为当前版本全量测试成绩。

10.3 三大核心业务模块功能验证

完整评测中，来源独立性修复影响 7 道题，撤回 4 个不同 Claim 在重复调查中累计 22 次不充分确认，并保留原有冲突。C08/C09 的 6 个新角色产物已从数据库读回，33 条引用核对了来源哈希、定位指针与核验产物。表 21 按模块汇总对应材料。 前端浏览器记录还覆盖了一次新调查的表单提交、进度、结果与证据展示，以及一次缺版本请求返回 NEED_CONTEXT；C09 与人工复核状态通过已有调查读取展示。

表 21 三大核心业务模块功能验证材料与工程达标结论

核心业务模块	关键验证内容	已封存的工程实证材料	模块验证达标结论
情报监测模块	7 大类异构源适配、RawDocument 原文快照封存、Normalizer 标准化、Checkpoint 增量续采	三类核心源实机采集批次记录、RawDocument SHA-256 指纹、情报 API 投影（E08、E09、E11）	已取得有限真实批次的拉取、入库及断点记录，覆盖情况由原始批次回执给出

核心业务模块	关键验证内容	已封存的工程实证材料	模块验证达标结论
情报富化模块	六维依赖编排、CVSS/CWE 校验、多维护分支版本解析、PoC/Patch 分级、origin() 血缘消歧	结构化事实转换记录、VersionObservation 回执、血缘消歧前后对比补丁与回归日志（E04、E14、E15）	修复记录支持同源重复确认被撤回；版本范围与修复建议可关联回原始字段
情报问答模块	受约束 DAG 规划与必需任务补齐、三角色协同推理、六维 Gate 验收、AnswerEnvelope 交付	C08/C09 实机 HTTP 完整报文、vLLM 0.6.5 调查记录、49 题 AegisBench 评测结果（E05、E12、E14）	真实 HTTP 案例已执行计划、取证、核验与交付；整题及风险匹配另按表 22 统计

10.4 AegisBench 评测基准与实验环境配置

为客观评估系统在复杂安全场景下的端到端自动问答表现，项目构建了包含 49 道人工精标审批题目的评测基准 AegisBench（数据集版本：AegisBench-v0.4-human49-20261014，49/49 题目状态均为 APPROVED），涵盖事实核查（5 题）、版本受影响判定（17 题）、PoC 与补丁状态分析（10 题）、资产风险与优先级评估（10 题）以及跨公告多跳关联推理（7 题）五大题型，共计 94 个细粒度评分字段。标准答案（Gold）仅在离线评分器中使用，严禁进入业务运行时上下文。

在实验环境配置上，完整评测运行于本地 Ollama 兼容模型服务之上，规划模型采用 aegisai-qwen25-planner:latest（模型权重 SHA-256 摘要以 15aaf3fda3b8 开头，基底模型为 qwen2.5:7b-instruct-q4_K_M），采样参数固定为 temperature=0、max_tokens=4096、单次模型调用超时 60 秒、Planner 最大尝试次数 2 次；评测输入采用 19 份冻结的真实公开安全公告与资料快照进行确定性重放（环境冻结清单与哈希见附录 A）。

10.5 团队最新自测汇总与结果说明

团队提供的最新自测汇总为：整题匹配 35/49，字段匹配 77/94，风险等级匹配 7/10。表 22 按三项指标分别列示样本范围。数据来源为团队于 2026 年 10 月 19 日提供的最新自测汇总，本次材料同步未重新运行评测；这些自动匹配结果不直接等同于人工确认的语义准确率。

表 22 团队最新自测汇总

指标	团队最新自测汇总	统计范围
整题匹配	35/49（71.43%）	49 道题
字段匹配	77/94（81.91%）	94 个字段
风险等级匹配	7/10（70.00%）	10 项风险字段

10.6 配对实验中的局部机制对照

配对实验在相同问题与冻结证据基础上比较 8 道主要题。C08 中，系统保留 1.x 分支下界及修复版本 1.2.5，普通模型省略下界并扩大了迁移建议；C09 中，系统避免了“0.29.0 早于 0.25.1”的错误排序和代码引用归因。两例支持具体的分支处理与引用行为。C03、C12 则显示普通模型对适用条件的说明更具体，原始评审与反例均保留。仅在这 8 个样本中验证本项目机制优势；样本量有限，不足以证明全部场景下的相对性能。

10.7 综合测试结果与端到端响应耗时分析

表 23 汇总不同阶段的工程测试记录，覆盖范围与模型环境分别列示。在本地单机真实调查中，C08 端到端耗时 52.50 秒，C09（含一次规划修正）为 46.50 秒；该记录包含模型调用、工具执行和状态轮询。封存答案可由读取接口再次查询，尚无统一负载条件下的吞吐量结论。

表 23 AegisAI 跨阶段工程自动化测试与契约验证记录汇总

测试阶段与套件名称	自动化测试通过记录	测试覆盖范围与环境配置	工程审计与核对方式
早期后端全量回归套件	1,261 项通过（0 失败）	覆盖采集器、标准化、基础富化与早期编排接口	封存构建日志尾部记录（附录 E04）
证据链修订版后端全量套件	1,426 项通过，0 失败，0 跳过	独立空 PostgreSQL 实例 + Mock LLM，全量覆盖 Runtime、核验与 Gate	docs/phase12d3/verification.json 原件（附录 E04）
证据链修订版前端测试套件	23 项通过（100% 通过）	覆盖前端路由、状态轮询与结构化答案渲染组件	前端测试封存报告（附录 E02、E04）

测试阶段与套件名称	自动化测试通过记录	测试覆盖范围与环境配置	工程审计与核对方式
前后端接口契约一致性校验	TypeScript 编译 PASS；42 个 HTTP 契约操作全通过	校验后端 OpenAPI 模型与前端请求/响应类型定义的一致性	全工程协议自动化检查记录（附录 E04）
AegisBench 评测工具链套件	48 项新增专项测试全部通过	覆盖评测 Runner、冻结数据加载器、分母锁定与状态比对契约	阶段测试验证报告（附录 E06、E12）
跨源血缘独立性修复回归	12 项专项通过；关联 88 项获通过覆盖，其中 1 项补配测试数据库后单独通过	针对 origin() 血缘归并、evaluate_claim 支持度统计与冲突保留逻辑	outputs/final-evidence-quality-review/regression-results.md（附录 E15）

第十一章 创新点总结

11.1 面向 AI 安全场景的受约束多 Agent 自主调查架构

任务完整性由服务端契约与模型规划共同保障。模型保留工具组合能力，服务端保留原始请求中的必要业务步骤；这一分工使计划生成和执行许可形成清晰边界。实现与算法集中见第 7.4.1 节。

11.2 跨源同出处消歧的 Evidence 可信安全分析机制

证据核验同时考虑声明内容与共同出处。系统分别保存原文、支持关系和来源组，避免把转载数量直接转换为独立支持强度，并让争议结论保留可回查依据。

11.3 包生态与维护分支约束的资产风险判定闭环

资产影响判断以包生态、包名、维护分支与登记版本为共同前提。由范围判断到修复建议的连接保留对应证据，便于分析人员核实建议适用于哪个组件和分支。

11.4 核心创新机制与赛题评分要求映射

表 24 将三项技术特点与赛题要求对应，作为实现章节和案例的阅读索引。

表 24 AegisAI 核心技术创新机制、实现入口与赛题评分体系对应

核心技术创新点	解决的 AI 安全情报痛点	核心代码实现入口与契约
服务端必需任务不变量与受约束 DAG 编排	大模型自由规划易遗漏资产读取或版本检测步骤，导致无依据盲目作答	服务端任务契约与计划复验，见第 7.4.1 节
跨源同出处血缘（Lineage）消歧与声明级核验	NVD/OSV/GHSA 互相转载同一公告，按 URL 计数易伪造“多源独立确认”	共同出处归组与声明核验，见第 7.4.2 节

核心技术创新点	解决的 AI 安全情报痛点	核心代码实现入口与契约
包生态与多维护分支约束的资产快照匹配闭环	上游仓库与下游 PyPI 包版本空间不同，多维护分支并行时易发生修复版本错配	包身份、版本比较与建议证据绑定，见第 7.4.3 节

第十二章 应用价值与未来展望

12.1 典型行业落地应用场景

系统适用于 AI 基础设施漏洞排查、登记软件组件清单的供应链核验，以及高校安全分析实训。它把来源检索、版本比对与证据整理串联为可复查过程，为升级决策提供材料与依据；企业部署仍需结合实际资产、运行条件和处置政策。

12.2 未来演进与技术扩展工作

后续优先完善用户命名政策与实际规则版本的绑定，补充公告内部范围差异检查，并扩展独立保留评测集与人工语义核验。工程方面重点验证跨平台 Worker、并发、取消和恢复行为，再推进部署自动化；利用验证与补丁落地须在授权环境中单独验收。

参考文献

[1] NIST. National vulnerability database[EB/OL]. [2026-10-14]. https://nvd.nist.gov.

[2] OSV. Open source vulnerabilities[EB/OL]. [2026-10-14]. https://osv.dev.

[3] 奇安信科技集团股份有限公司. “中国电子杯”第三届高校 ICT 产教融合创新大赛赛题九：智能体驱动的 AI 安全知识情报系统设计与实现[Z]. 2026.

[4] FIRST. Common vulnerability scoring system version 3.1: Specification document[EB/OL]. (2019-06-01)[2026-10-14]. https://www.first.org/cvss/v3.1/specification-document.

[5] MITRE. Common weakness enumeration: About CWE[EB/OL]. [2026-10-14]. https://cwe.mitre.org/about/index.html.

[6] RAMÍREZ S. FastAPI documentation[EB/OL]. [2026-10-19]. https://fastapi.tiangolo.com/.

[7] SQLAlchemy. SQLAlchemy 2.0 documentation[EB/OL]. [2026-10-14]. https://docs.sqlalchemy.org.

[8] PostgreSQL Global Development Group. PostgreSQL documentation[EB/OL]. [2026-10-14]. https://www.postgresql.org/docs/.

[9] LANGCHAIN AI. LangChain serialization injection vulnerability enables secret extraction in dumps/loads APIs (GHSA-c67j-w6g6-q2cm)[EB/OL]. [2026-10-18]. https://github.com/langchain-ai/langchain/security/advisories/GHSA-c67j-w6g6-q2cm.

[10] VLLM PROJECT. Harmony tool continuations drop cache_salt — restoring a cross-tenant prefix-cache membership oracle (GHSA-935w-9g4m-p28p)[EB/OL]. [2026-10-18]. https://github.com/vllm-project/vllm/security/advisories/GHSA-935w-9g4m-p28p.

[11] VLLM PROJECT. Security advisory GHSA-hjq4-87xh-g4fv[EB/OL]. [2026-10-14]. https://github.com/vllm-project/vllm/security/advisories/GHSA-hjq4-87xh-g4fv.

附录 A 工程证据索引与可复现清单

为确保本报告所有架构设计、核心代码、实机运行案例（C08、C09、vLLM 0.6.5）及 AegisBench 评测结果完全可核查、可复现，本附录完整列出工程冻结清单、模型权重指纹、关键产物 SHA-256 哈希及按项目根目录相对路径组织的工程证据索引（表 26）。

工程版本冻结与核心实证文件 SHA-256 指纹核对清单 (Environment & Artifact Freeze Manifest)

```
01  环境与版本清单 : outputs/final-accuracy-validation/environment-freeze.json
02  环境清单 SHA256: 0d331edf4002c8dadeebf5547fcad78c1f9fc6e9edcef1dea55fbb4babdbc9a2
03  评测基准数据集 : AegisBench-v0.4-human49-20261014 (49/49 APPROVED)
04  基础 Git 提交  : 88741c7e5ed0d3d684a89ba9bcb67021850c8314 (含冻结清单记录的增量补丁)
05  规划模型指纹   : aegisai-qwen25-planner:latest (qwen2.5:7b-instruct-q4_K_M)
06  模型 Digest    : 15aaf3fda3b8e9bb6724e5e9911eec3b9cbdb6bd967646b6bf49ee9846b7ec16
07  C08 调查 Run ID: 78eabee2-b88b-4b39-b39d-7536f4350b41 (outputs/final-live-demo/live-C08.json)
08  C08 文件 SHA256: 7f9035c93f545ae8b1ef697cd6cf049d58b0353c8bffc6a6809fe83b18bd0ed1
09  C09 调查 Run ID: 37a0d8a1-3bfd-49f8-b841-21009fed28b8 (outputs/final-live-demo/live-C09.json)
10  C09 文件 SHA256: 0a9a5c182e8e77a832d8656f55b76f61487d9b5cbc8d51459670a97c21d04207
11  49 题结果文件   : outputs/final-accuracy-validation/49-question-results.json
12  49 题结果 SHA256: 600d610e9c9ddcca2062d8e1f1624ec79ab5a26a1ddd6e291ed97b4f448fcc69
```

表 26 AegisAI 工程源码、实机运行产物与测试验证证据索引（E01—E22）

证据编号	工程相对路径与材料名称	支撑的报告章节与核心实证内容
E01	requirements/sources/competition_problem_9.pdf（第 2–3 页）	初赛作品提交要求、核心亮点预览页规范、核心代码说明及 100 分评分标准映射

证据编号	工程相对路径与材料名称	支撑的报告章节与核心实证内容
E02	backend/app/、backend/requirements.txt、frontend/package.json、CURRENT_STATUS.md	系统实际技术栈选型、四角色智能体、自研 DAG Runtime、REST API 与前端工程实现
E03	docs/INTEGRATION_GATE_IMPLEMENTATION.md、backend/app/integration/	Integration Gate 六维检查规则、状态裁定优先级、证据链完整性与目标覆盖实现
E04	PHASE_12D3_RESULT.md、docs/phase12d3/verification.json	证据链修订版封存观察、1,426 项后端回归测试通过、23 项前端测试与 42 项契约验证原件
E05	docs/phase12d3/real-http-post-review.json、demo/phase12d3/README.md	历史基线 vLLM 0.6.5（GHSA-hjq4-87xh-g4fv）真实模型规划与 HTTP 端到端调查记录
E06	PHASE_13B_RESULT.md、evaluation/reports/phase13b-final-20261011/report.json	评测框架工程接入、48 项 Runner 测试及基准配置材料
E07	PHASE_13C_RESULT.md、PHASE_13D_PROGRESS.md、evaluation/ground_truth/	AegisBench 49 题人工标注规范、审批历史记录与 Gold 标准答案库
E08	reports/phase6/、reports/phase7/、backend/app/collectors/、backend/app/enrichment/	多源情报采集器、Checkpoint 增量同步、Normalizer 标准化与六维富化器实现记录
E09	PHASE_14A_RESULT.md、docs/phase14a/（来源矩阵、live-validation、verification-summary）	结构化漏洞库、Trail of Bits 博客 RSS、arXiv 论文适配与实机入库验证材料
E10	work/local_demo_runtime/dashboard-before.png	本地运行工作台与情报态势页面实机截图记录
E11	docs/phase14a/live-intelligence-example.json	脱敏真实情报 API 字段投影（含 CVE-2022-45907 与 CVE-2025-32434 多维富化输出）
E12	outputs/final-accuracy-validation/FINAL_ACCURACY_VALIDATION_RESULT.md；49-question-results.json/csv	最新 49 题完整基准实验请求、评分输入、逐题匹配明细与环境冻结清单

证据编号	工程相对路径与材料名称	支撑的报告章节与核心实证内容
E13	outputs/phase14c25/PHASE_14C25_RESULT.md；final-source-freeze.json；failure-ledger.json	C25 历史完整实验基线（16/49 整题、43/94 字段）、冻结源码快照与演进对比依据
E14	outputs/final-live-demo/FINAL_LIVE_DEMO_RESULT.md；live-C08.json；live-C09.json；actual-wire.jsonl；live-evidence-reference-matrix.csv	C08 与 C09 实机 HTTP 调查原始请求、完整响应、模型底层报文（actual-wire）及 33 条证据引用定位矩阵
E15	outputs/final-evidence-quality-review/FINAL_EVIDENCE_QUALITY_REVIEW.md；minimal-production-change.patch；regression-results.md	origin() 跨源同出处血缘归并规则增量补丁、纠正 22 次重复确认实证及 12/88 项回归测试日志
E16	outputs/final-correctness-comparison/final-advantage-verdict/FINAL_ADVANTAGE_VERDICT.md；evidence-adjudication.csv	AegisAI 与单次模型回答配对对照实验设计、证据裁定矩阵与典型案例分析
E17	outputs/final-correctness-comparison/final-human-adjudication/FINAL_HUMAN_ADJUDICATION.md；reviewer-provenance-audit.csv	三位真人评审独立评价记录、分歧裁定与审计说明
E18	outputs/final-submission-package/FINAL_SUBMISSION_PACKAGE_CHECK.md；demo-steps.md；preparation-checks.json	本地后端服务启动、源码哈希核对、实机演示步骤说明与环境检查记录
E19	outputs/phase14c25/backup-receipt.json；backups/restore-verification.json	源码包、原始证据与 PostgreSQL 数据库备份及真实恢复数量核对回执
E20	outputs/final-accuracy-diff/FINAL_ACCURACY_DIFF.md；outputs/final-readiness/core-scenarios.json	C25 至最新版本逐字段变化归因分析、NEED_CONTEXT 与冲突分流核心场景记录
E21	outputs/phase14c28/PHASE_14C28_RESULT.md；regression-results.json；process-launch-diagnostics.md	跨平台进程启动诊断、Worker 执行日志与运行环境边界分析材料
E22	GitHub: frontend/wang-investigation-workbench@e982b400 frontend/public/modules/pages/、modules/wb-ui.js outputs/final-video-prep/FRONTEND_READINESS.md；本版截图与源码对照记录	总览、资产/复核详情、搜索和调查工作台实现；既有真实浏览器调查记录与本次只读页面截图